

TECNOLOGIA DA INFORMAÇÃO

Gestão de Segurança da Informação:
Norma NBR ISO/IEC n. 27001:2022



Presidente: Gabriel Granjeiro

Vice-Presidente: Rodrigo Calado

Diretor Pedagógico: Erico Teixeira

Diretora de Produção Educacional: Vivian Higashi

Gerente de Produção Digital: Bárbara Guerra

Coordenadora Pedagógica: Élica Lopes

Todo o material desta apostila (incluindo textos e imagens) está protegido por direitos autorais do Gran. Será proibida toda forma de plágio, cópia, reprodução ou qualquer outra forma de uso, não autorizada expressamente, seja ela onerosa ou não, sujeitando-se o transgressor às penalidades previstas civil e criminalmente.

CÓDIGO:

250701297306



PATRÍCIA QUINTÃO

Mestre em Engenharia de Sistemas e computação pela COPPE/UFRJ, Especialista em Gerência de Informática e Bacharel em Informática pela UFV. Atualmente é professora no Gran Cursos Online; Analista Legislativo (Área de Governança de TI), na Assembleia Legislativa de MG; Escritora e Personal & Professional Coach. Atua como professora de Cursinhos e Faculdades, na área de Tecnologia da Informação, desde 2008. É membro: da Sociedade Brasileira de Coaching, do PMI, da ISACA, da Comissão de Estudo de Técnicas de Segurança (CE-21:027.00) da ABNT, responsável pela elaboração das normas brasileiras sobre gestão da Segurança da Informação. Autora dos livros: Informática FCC – Questões comentadas e organizadas por assunto, 3ª. edição e 1001 questões comentadas de informática (Cespe/UnB), 2ª. edição, pela Editora Gen/Método. Foi aprovada nos seguintes concursos: Analista Legislativo, na especialidade de Administração de Rede, na Assembleia Legislativa do Estado de MG; Professora titular do Departamento de Ciência da Computação do Instituto Federal de Educação, Ciência e Tecnologia; Professora substituta do DCC da UFJF; Analista de TI/Suporte, PRODABEL; Analista do Ministério Público MG; Analista de Sistemas, DATAPREV, Segurança da Informação; Analista de Sistemas, INFRAERO; Analista – TIC, PRODEMGE; Analista de Sistemas, Prefeitura de Juiz de Fora; Analista de Sistemas, SERPRO; Analista Judiciário (Informática), TRF 2ª Região RJ/ES, etc.

GRAN
CONCURSOS

SUMÁRIO

Apresentação	5
Gestão de Segurança da Informação: Norma NBR ISO/IEC n. 27001:2022	8
Seções (Estrutura) da Norma ABNT NBR ISO/IEC 27001:2022, Versão Corrigida:2023.	8
1. Escopo	11
2. Referências Normativas	12
3. Termos e Definições	13
4. Contexto da Organização	15
4.1. Entendendo a Organização e seu Contexto	15
4.2. Entendendo as Necessidades e as Expectativas das Partes Interessadas .	15
4.3. Determinando o Escopo do Sistema de Gestão da Segurança da Informação	15
4.4. Sistema de Gestão da Segurança da Informação	16
5. Liderança	16
6. Planejamento	18
6.1. Ações para Abordar Riscos e Oportunidades	18
6.2. Objetivos da Segurança da Informação e Planejamento para Alcançá-los .	19
6.3. Planejamento de Mudanças	20
7. Apoio	20
8. Operação	22
9. Avaliação do Desempenho	23
10. Melhoria	23
10.1. Melhoria Contínua	23
10.2. Não Conformidade e Ação Corretiva	23
Resumo	25
Questões Comentadas em Aula	29
Exercícios	31

Gabarito	38
Gabarito Comentado.....	39
Referências	63
Anexo.....	64

APRESENTAÇÃO

Olá, querido(a) amigo(a)! É um prazer revê-lo(a).

A norma ISO/IEC 27001, referência na área da **gestão da segurança da informação**, teve a sua publicação em 23 de novembro de 2022, passando a ser intitulada **ABNT NBR ISO/IEC 27001:2022 Segurança da informação, segurança cibernética e proteção à privacidade — Sistemas de gestão da segurança da informação — Requisitos**.

Terceira edição
23.11.2022

Segurança da informação, segurança cibernética e proteção à privacidade — Sistemas de gestão da segurança da informação — Requisitos

Information security, cybersecurity and privacy protection — Information security management systems — Requirements

A Norma ABNT NBR ISO/IEC 27001:2022 é uma parte fundamental da família de normas ISO/IEC 27000, e aborda o **Sistema de Gestão da Segurança da Informação (SGSI)**. Ela cancela e substitui a ABNT NBR ISO/IEC 27001:2013, a qual foi tecnicamente revisada.

Em 31/03/2023, a Norma ABNT NBR ISO/IEC 27001:2022 incorporou a Errata 1, tornando-se a **ABNT NBR ISO/IEC 27001:2022, Versão Corrigida:2023**.

NORMA
BRASILEIRA

ABNT NBR
ISO/IEC
27001

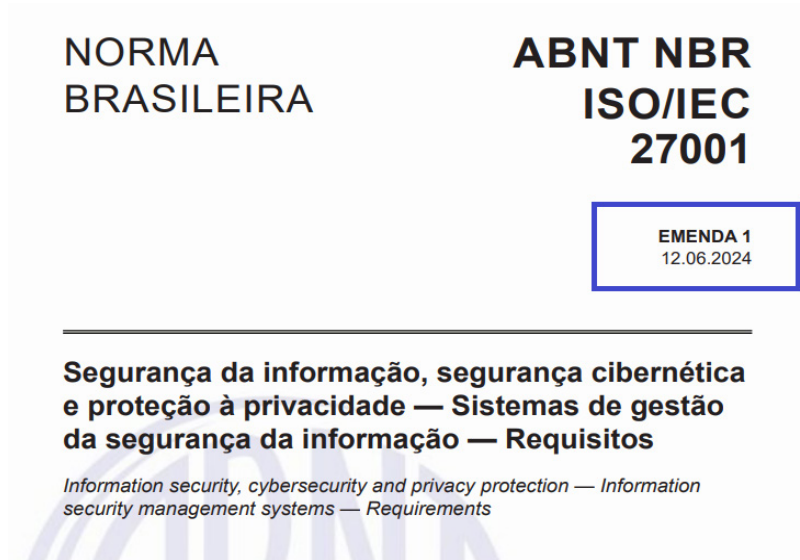
Terceira edição
23.11.2022

Versão corrigida
31.03.2023

Segurança da informação, segurança cibernética e proteção à privacidade — Sistemas de gestão da segurança da informação — Requisitos

Information security, cybersecurity and privacy protection — Information security management systems — Requirements

Em 12.06.2024, foi lançada a **Emenda 1** da **ABNT NBR ISO/IEC 27001:2022, Versão Corrigida:2023**. “Esta Emenda é uma adoção idêntica no conteúdo técnico, estrutura e redação da “Emenda de Ação Climática” às Normas de Sistemas de Gestão (MSS) ABNT NBR ISO existentes e novas, para refletir os compromissos de ação climática da ISO”.



Essa última Emenda **não** será incorporada ao documento original, até a ocasião da próxima revisão da **ABNT NBR ISO/IEC 27001:2022, Versão Corrigida:2023**, não alterando o ano de publicação da versão mais recente da Norma Brasileira. Veja a **Emenda 1** na íntegra a seguir:

NORMA BRASILEIRA	ABNT NBR ISO/IEC 27001:2022/Em1:2024
------------------	--------------------------------------

Segurança da informação, segurança cibernética e proteção à privacidade — Sistemas de gestão da segurança da informação — Requisitos

EMENDA 1

Página 1, Subseção 4.1

Incluir, ao final da subseção:

A organização deve determinar se o assunto “mudanças climáticas” é pertinente.

Página 2, Subseção 4.2

Incluir NOTA, ao final da subseção:

NOTA 2 As partes interessadas pertinentes podem possuir requisitos relacionados às mudanças climáticas.

Nesta aula, exploraremos diversas questões relacionadas à norma, com ênfase nos conceitos mais abordados pelas bancas.

Desde 2006, faço parte da Comissão de Estudo de Técnicas de Segurança (CE-21:027.00), que é responsável pela elaboração das normas de segurança no Brasil, sob a coordenação da ABNT. É importante destacar que, durante a criação ou tradução de uma norma, ela passa por várias revisões no comitê, sendo posteriormente submetida a consulta pública. Somente após esse processo, a versão oficial é homologada e disponibilizada para venda pela ABNT.

Vamos então ao que interessa! 😊

Um abraço, **prof.^a Patrícia Quintão** | Instagram: @patricialquintao

GESTÃO DE SEGURANÇA DA INFORMAÇÃO: NORMA NBR ISO/IEC N. 27001:2022

SEÇÕES (ESTRUTURA) DA NORMA ABNT NBR ISO/IEC 27001:2022, VERSÃO CORRIGIDA:2023

A **Norma ABNT NBR ISO/IEC 27001:2022, Versão Corrigida: 2023**, é dividida em **11 seções e Anexo A**.

As **seções de 0 a 3 são introdutórias** (e **não** são obrigatórias para a implementação), enquanto **as seções de 4 a 10 são obrigatórias** – significando que TODOS os seus **requisitos** devem ser implementados em uma organização se ela quer estar em conformidade com a norma.

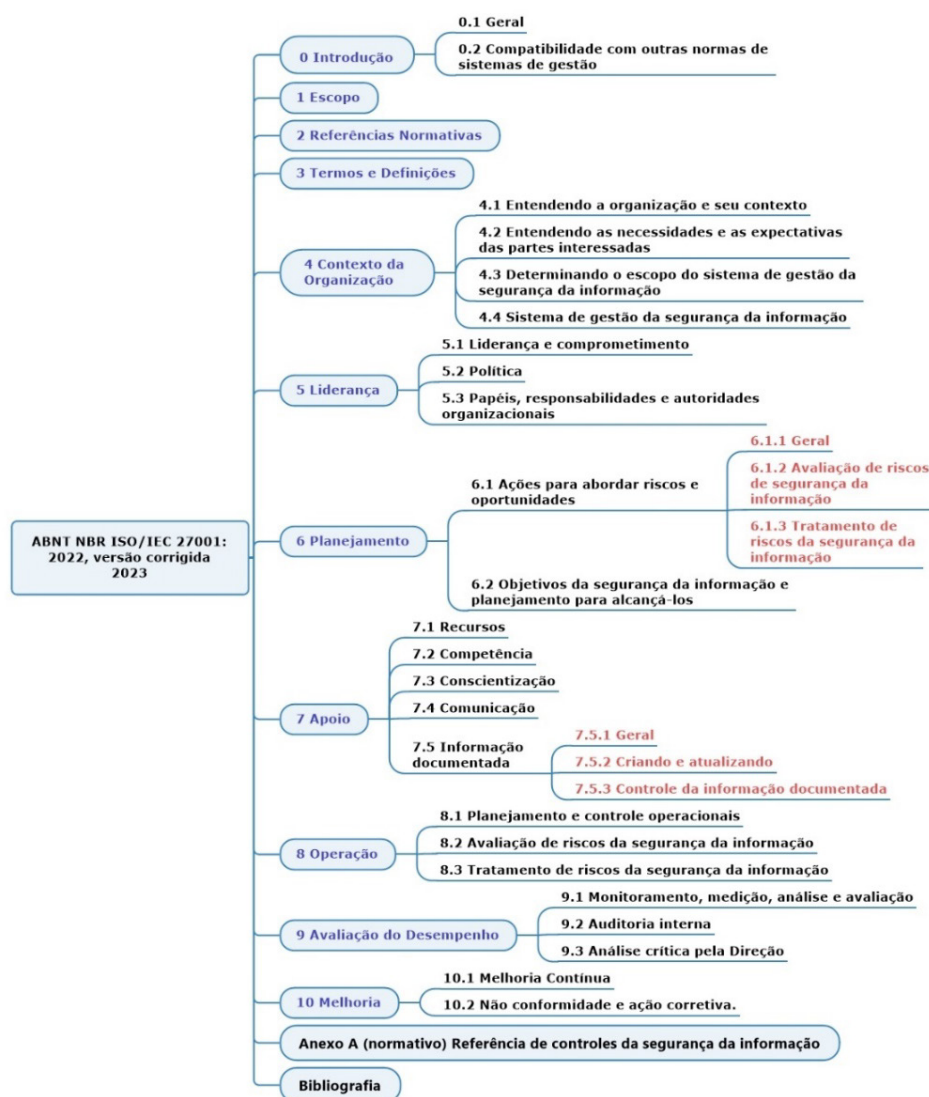


Figura. Seções da Norma ABNT NBR ISO/IEC 27001:2022, Versão Corrigida: 2023 (QUINTÃO, 2024)

Seção 0: Introdução	Destaca o propósito da ISO 27001 e sua compatibilidade com outras normas de gestão.
Seção 1: Escopo	Explica que a norma é aplicável a qualquer tipo de organização.
Seção 2: Referências normativas Seção 3: Termos e definições	Refere-se à ISO / IEC 27000 como uma norma em que referências normativas, termos e definições são dadas.
Seção 4: Contexto da organização	Descreve o contexto da organização, incluindo o ambiente interno e externo, as necessidades e expectativas das partes interessadas e os objetivos de segurança da informação
Seção 5: Liderança	Descreve os requisitos de liderança para o SGSI, incluindo a política de segurança da informação, a atribuição de papéis e responsabilidades.
Seção 6: Planejamento	Descreve os requisitos de planejamento para o SGSI, incluindo o risco de segurança da informação, o tratamento de riscos e os objetivos de segurança da informação e planejamento para alcançá-los.
Seção 7: Apoio	Descreve os requisitos de apoio para o SGSI, incluindo recursos, competência das pessoas, conscientização, comunicação e informação documentada.
Seção 8: Operação	Descreve os requisitos de operação para o SGSI, incluindo atividades de planejamento e controle operacionais, avaliação/tratamento dos riscos de segurança da informação.
Seção 9: Avaliação do desempenho	Define requisitos para o monitoramento, medição, análise/avaliação, auditoria interna e análise crítica pela Direção.
Seção 10: Melhoria	Descreve os requisitos de melhoria para o SGSI, incluindo a melhoria contínua e requisitos para não conformidades e ações corretivas.

O Anexo A da norma ABNT ISO/IEC 27001:2022, versão corrigida 2023, lista 93 controles de segurança da informação que podem ser usados para implementar um sistema de gestão de segurança da informação (SGSI).

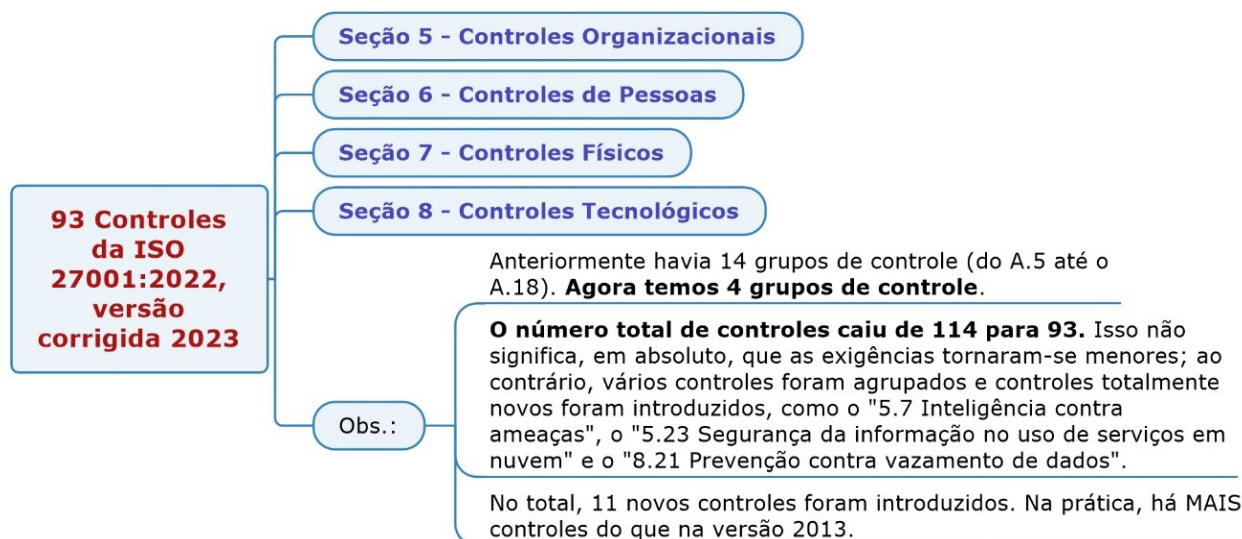
Os controles são organizados em quatro domínios:

Controles organizacionais (37 controles)

Controles de pessoas (8 controles)

Controles físicos (14 controles)

Controles tecnológicos (34 controles)



Os controles do Anexo A não são obrigatórios, mas são uma boa prática para organizações que desejam implementar um SGSI eficaz. O grau de implementação de cada controle deve ser determinado pela organização, levando em consideração seus riscos e necessidades específicos.

O **Anexo A** é uma ferramenta valiosa para organizações que desejam entender os controles de segurança da informação disponíveis e como eles podem ser usados para implementar um SGSI eficaz.

DIRETO DO CONCURSO

001. (CESPE/TJ-PA/ANALISTA JUDICIÁRIO – ANÁLISE DE SISTEMAS (DESENVOLVIMENTO)/2020/ADAPTADA) Conforme a NBR ISO/IEC 27001 [versão 2022, corrigida em 2023], implementar e operar um sistema de gestão de segurança da informação (SGSI) no processo PDCA envolve o requisito

- definir a abordagem de como será realizada a análise e avaliação dos riscos na organização.
- realizar a medição da eficácia dos controles estabelecidos no SGSI para verificar se estão atendidos.
- integrar os stakeholders na comunicação das ações de melhoria.
- elaborar o plano de tratamento dos riscos, identificando-se as ações de gestão apropriadas, os recursos a serem utilizados e as responsabilidades para a gestão dos riscos em segurança da informação.
- obter autorização da direção da organização para a implementação e operação do SGSI.



Conforme a ABNT NBR ISO/IEC 27001: 2022, versão corrigida 2023, implementar e operar um sistema de gestão de segurança da informação (SGSI) envolve o requisito especificado na letra D, destacado a seguir:

d) elaborar o plano de tratamento dos riscos, identificando-se as ações de gestão apropriadas, os recursos a serem utilizados e as responsabilidades para a gestão dos riscos em segurança da informação.

Este requisito é essencial para garantir que os riscos identificados sejam adequadamente tratados e gerenciados dentro do SGSI.

Conforme visto, a seção 8, intitulada **Operação**, parte da etapa execução (**Do**) do ciclo PDCA e **define a implementação da avaliação e tratamento de riscos da segurança da informação, assim como controles e outros processos necessários para atingir os objetivos de segurança da informação.**

8 Operação

...

8.3 Tratamento de riscos de segurança da informação

A organização deve implementar o plano de tratamento de riscos da segurança da informação.

A organização deve reter informação documentada dos resultados do tratamento de riscos da segurança da informação.

Letra d.

1. ESCOPO

- A Norma NBR ISO/IEC 27001:2022, versão corrigida: 2023, especifica os **requisitos para estabelecer, implementar, manter e melhorar continuamente (EIMM)** um **sistema de gestão de segurança da informação (SGSI)** dentro do contexto da organização.

Lembre-se do famoso “**EIMM**” para as quatro etapas, que são:

- 1 – E:** Estabelecer
- 2 – I:** Implementar
- 3 – M:** Manter
- 4 – M:** Melhorar

- Também inclui requisitos para a avaliação e tratamento de riscos de segurança da informação voltados para as necessidades da organização.**

- Os requisitos definidos neste documento são **genéricos** e é pretendido que sejam **aplicáveis a TODAS as organizações, independentemente do tipo, tamanho ou natureza**.
- A exclusão de quaisquer dos requisitos especificados nas Seções 4 a 10 **não é aceitável quando a organização busca a conformidade com esta norma**.

QUESTÃO INÉDITA

002. (INÉDITA/2024) A norma ISO/IEC 27001:2022, versão corrigida 2023, trata

- a) da gestão de riscos em sistemas de gestão da segurança da informação.
- b) de requisitos de sistema de gestão da segurança da informação, métricas e medidas, e diretrizes para implementação.
- c) de requisitos para auditoria e certificação de um sistema de gestão da segurança da informação.
- d) das recomendações de controles para segurança da informação da antiga ISO/IEC 17799.
- e) de requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação dentro do contexto da organização.



Vide os comentários extraídos da p. 1 da norma ISO/IEC 27001:2022: “**esta Norma especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente (EIMM) um Sistema de Gestão de Segurança da Informação (SGSI)** dentro do contexto da organização. Também inclui **requisitos para a avaliação e tratamento de riscos de segurança da informação voltados para as necessidades da organização**.”

Letra e.

2. REFERÊNCIAS NORMATIVAS

O documento **ISO/IEC 27000**, *Information Technology – Security Techniques – Information Security Management Systems – Overview and Vocabulary* é **indispensável à aplicação a esta Norma**.

A **norma ISO/IEC 27000** apresenta uma **introdução geral de um sistema de gestão de segurança da informação** e da **família de normas** da série ISO/IEC 27000.

A ISO/IEC 27000 fornece um **glossário**, contendo definições da maioria dos termos usados em toda a família de normas da série ISO/IEC 27000, e descreve o escopo e objetivos para cada membro da família.

3. TERMOS E DEFINIÇÕES

Para os efeitos deste documento, aplicam-se a esta Norma os termos e definições da **ISO/IEC 27000**. Alguns exemplos:

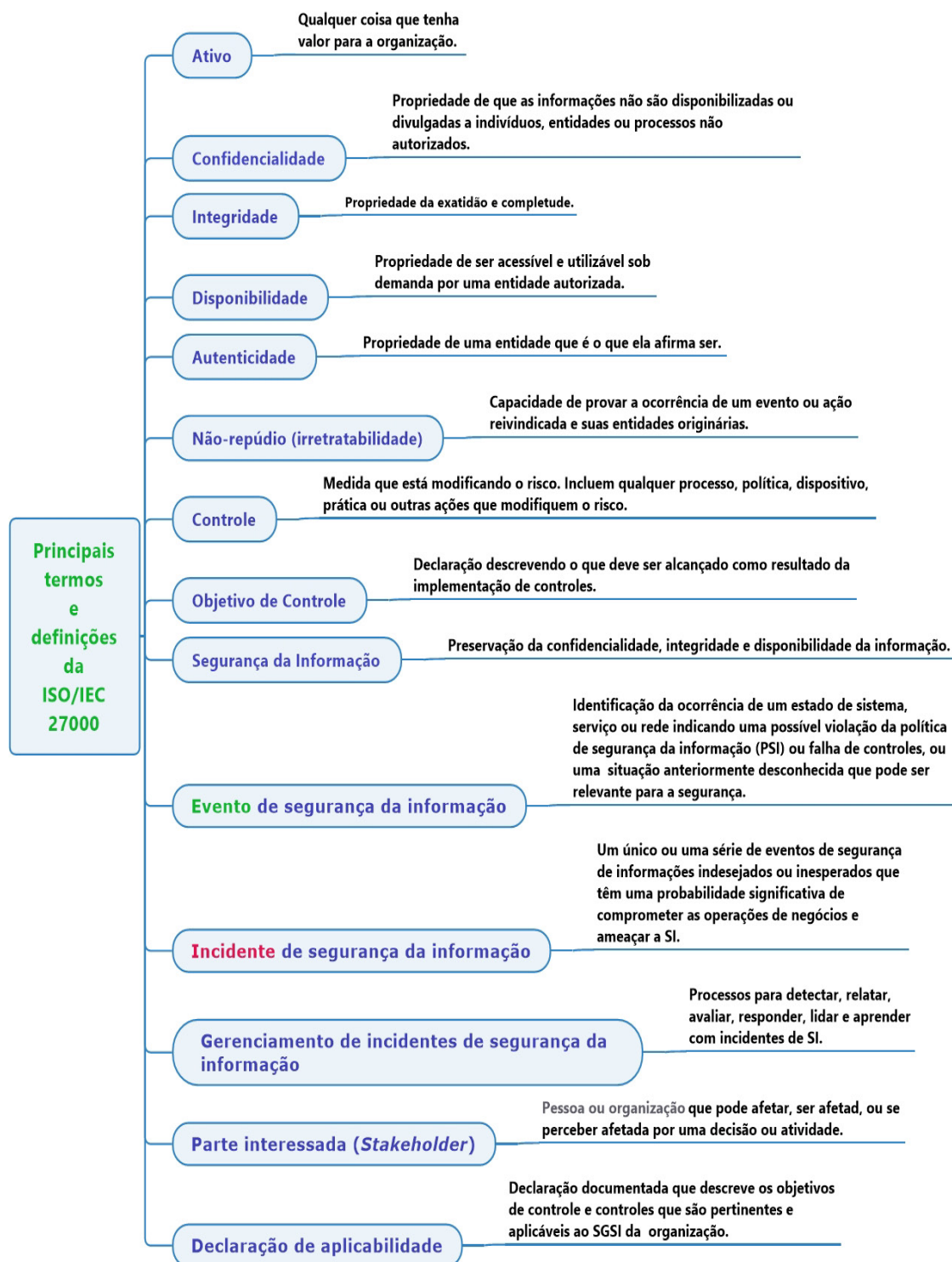


Figura. Termos e definições (Parte I). Fonte: Quintão (2024).

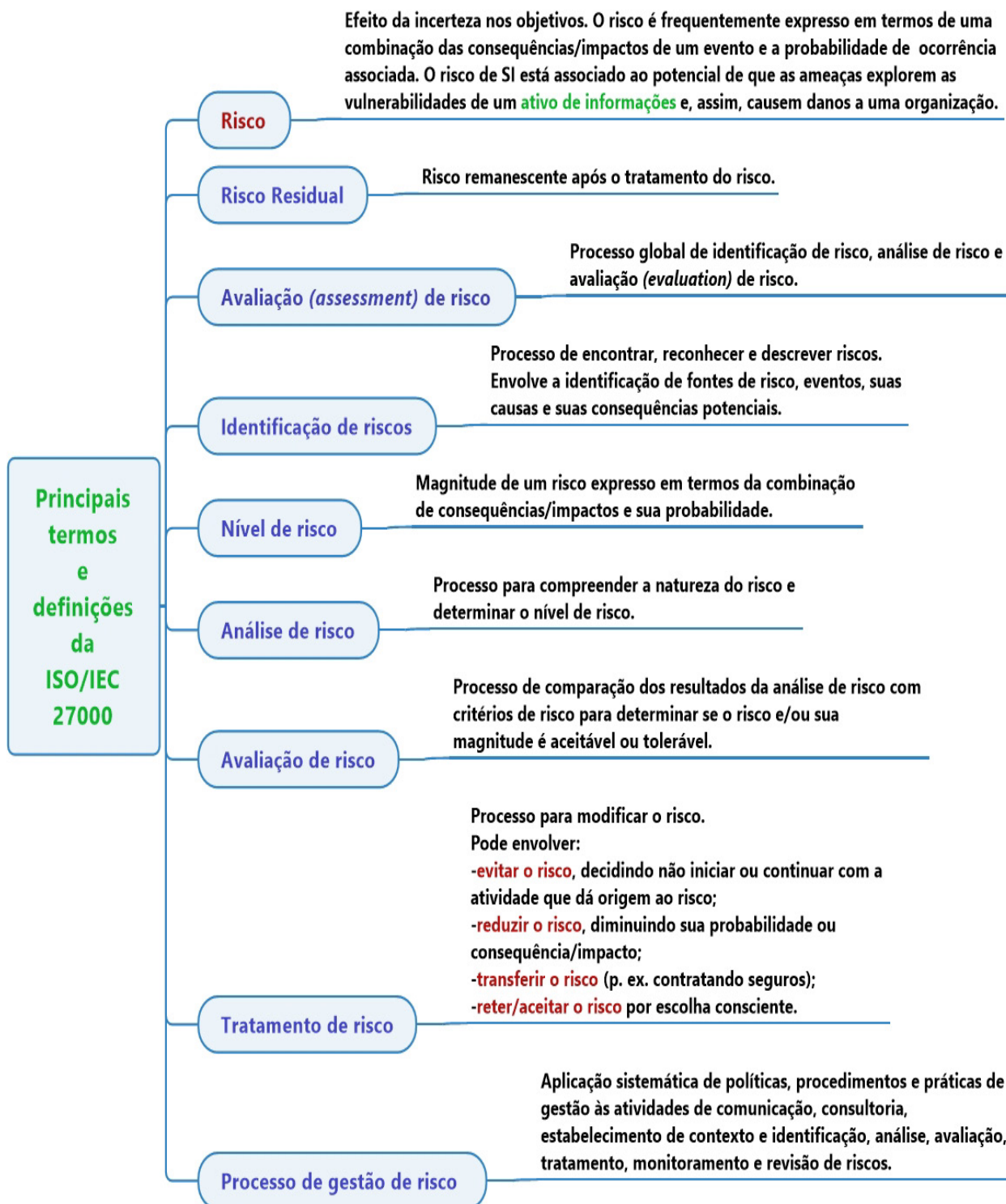


Figura. Termos e definições (Parte II). Fonte: Quintão (2024).

4. CONTEXTO DA ORGANIZAÇÃO

4.1. ENTENDENDO A ORGANIZAÇÃO E SEU CONTEXTO

A organização deve **determinar as questões internas e externas que são relevantes para o seu propósito** e que afetam sua capacidade de alcançar os resultados pretendidos do seu **SGSI**.

A organização deve determinar se o assunto “mudanças climáticas” é pertinente.

4.2. ENTENDENDO AS NECESSIDADES E AS EXPECTATIVAS DAS PARTES INTERESSADAS

A organização deve determinar:

- **as partes interessadas** que são relevantes para o **SGSI**;
- **os requisitos relevantes** dessas **partes interessadas**;
- **quais desses requisitos serão endereçados pelo SGSI**.

A organização deve determinar os **limites** e a **aplicabilidade** do **SGSI** para estabelecer o seu escopo.

Ao determinar este escopo, a organização deve considerar:

- a) as questões internas e externas referenciadas em 4.1;
- b) os requisitos referenciados em 4.2;
- c) as interfaces e dependências entre as atividades desempenhadas pela organização e aquelas que são desempenhadas por outras organizações.

O escopo deve estar disponível como informação documentada.

NOTA 2 As partes interessadas pertinentes podem possuir requisitos relacionados às mudanças climáticas.

4.3. DETERMINANDO O ESCOPO DO SISTEMA DE GESTÃO DA SEGURANÇA DA INFORMAÇÃO

A organização deve determinar os limites e a aplicabilidade do **SGSI** para estabelecer o seu escopo.

Ao determinar este escopo, a organização deve considerar:

- as questões internas e externas referenciadas em 4.1;
- os requisitos referenciados em 4.2;
- as interfaces e dependências entre as atividades desempenhadas pela organização e aquelas que são desempenhadas por outras organizações.

O escopo deve estar disponível como informação documentada.

4.4. SISTEMA DE GESTÃO DA SEGURANÇA DA INFORMAÇÃO

A organização deve estabelecer, implementar, manter e melhorar continuamente um **SGSI**, incluindo os processos necessários e suas interações, de acordo com os requisitos deste documento.

5. LIDERANÇA

• **A Alta Direção deve:**

1. demonstrar sua liderança e comprometimento em relação ao **SGSI, pelos seguintes meios:**

- a) assegurando que a **política de segurança da informação** e os **objetivos de segurança da informação** estejam estabelecidos e sejam compatíveis com a direção estratégica da organização;
- b) assegurando a **integração dos requisitos** do **SGSI** nos processos da organização;
- c) assegurando que os **recursos necessários** para o **SGSI** estejam **disponíveis**;
- d) **comunicando** a importância de uma gestão eficaz da segurança da informação e da conformidade com os requisitos do **SGSI**;
- e) **assegurando que o **SGSI** alcance seus resultados** pretendidos;
- f) **orientando e apoiando pessoas a contribuir para a eficácia do sistema de gestão da segurança da informação**;
- g) promovendo a **melhoria contínua**; e
- h) **apoiando outros papéis relevantes da gestão** para demonstrar como sua liderança se aplica às áreas sob sua responsabilidade.

2. Estabelecer uma **política de segurança da informação (PSI).**

A **PSI** deve estar disponível como informação documentada, ser comunicada dentro da organização e estar disponível para as partes interessadas, conforme apropriado.

3. Assegurar que as responsabilidades e autoridades dos papéis relevantes para a segurança da informação sejam atribuídos e comunicados dentro da organização.

A **Alta Direção** deve atribuir a responsabilidade e autoridade para:

- a) **assegurar que o **SGSI** está em conformidade com os requisitos desta Norma**;
- b) **relatar sobre o desempenho **SGSI** para a Alta Direção**.

DIRETO DO CONCURSO 

003. (CESPE/TCE-RO/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO/DESENVOLVIMENTO DE SISTEMAS/2019) De acordo com a NBR ISO/IEC n.º 27001:2022 [versão corrigida 2023], a

alta direção de uma organização deve demonstrar liderança e comprometimento em relação ao sistema de gestão da segurança da informação. Para isso, ela deve

I. assegurar que a política de segurança da informação seja compatível com a direção estratégica da organização.

II. comunicar a importância da conformidade com os requisitos do sistema de gestão da segurança da informação.

III. analisar criticamente os códigos quanto ao uso de técnicas de programação segura.

IV. orientar pessoas que contribuam para a eficácia do sistema de gestão da segurança da informação.

Estão certos apenas os itens

- a) I e II
- b) I e III
- c) III e IV
- d) I, II e IV
- e) II, III e IV



Vamos então aos comentários das assertivas:

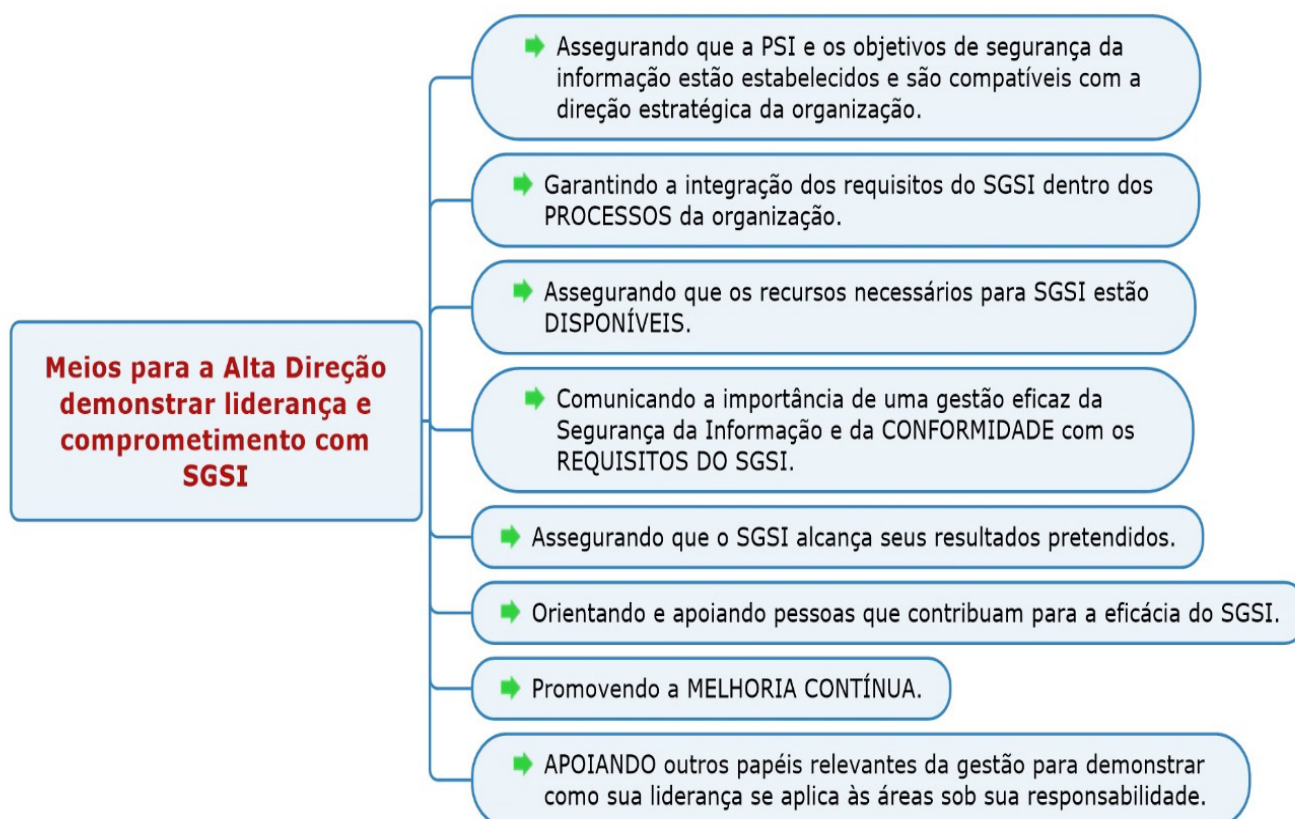


Figura. Elaboração própria (2024).

I – Certo. A Seção 5.1 da norma ISO/IEC 27001:2022 (versão corrigida 2023) destaca que “a Alta Direção deve demonstrar sua liderança e comprometimento em relação ao sistema de gestão da segurança da informação assegurando que **a política de segurança da informação e os objetivos de segurança da informação estejam estabelecidos e sejam compatíveis com a direção estratégica da organização**”.

II – Certo. A Seção 5.1 da norma ISO/IEC 27001:2022 (versão corrigida 2023) destaca que a Alta Direção deve comunicar a importância de uma gestão eficaz da segurança da informação e **da conformidade com os requisitos do sistema de gestão da segurança da informação (SGSI)**.

III – Errado. Analisar criticamente os códigos quanto ao uso de técnicas de programação segura **não** é papel da Alta Direção.

IV – Certo. A Seção 5.1 da norma ISO/IEC 27001:2022 (versão corrigida 2023) destaca que a **Alta Direção deve orientar e apoiar pessoas a contribuir para a eficácia do sistema de gestão da segurança da informação**.

Dessa forma, as assertivas I, II e IV estão corretas.

Letra d.

6. PLANEJAMENTO

6.1. AÇÕES PARA ABORDAR RISCOS E OPORTUNIDADES

- No **planejamento** do **SGSI**, a **organização deve considerar as questões referenciadas em 4.1 e os requisitos estabelecidos em 4.2, e determinar os riscos e oportunidades** que precisam ser abordados **para assegurar que o SGSI pode alcançar seus resultados pretendidos, prevenir ou reduzir os efeitos indesejados e alcançar a melhoria contínua**.
- A **organização deve planejar as ações** para abordar estes riscos e oportunidades; e como **integrar e implementar as ações dentro dos processos** do seu **SGSI**, além de como **avaliar a eficácia destas ações**.
- A **organização deve estabelecer** e aplicar um **processo de avaliação de riscos de Segurança da Informação (SI)** que:

a) estabeleça e mantenha os **critérios de aceitação do risco** e **critérios para realizar as avaliações dos riscos de SI**;

b) assegure que as **contínuas avaliações** de riscos de SI produzam **resultados comparáveis, válidos e consistentes**;

c) **identifique os riscos** de SI;

d) analise os riscos de SI, **avaliando** suas **consequências** potenciais, a **probabilidade** realística de **ocorrência** e os níveis de risco;

e) avalie os riscos de SI, **comparando** os resultados da **análise** dos riscos **com os critérios** de riscos estabelecidos e **priorizando** os **riscos analisados** para o tratamento do risco.

- A **organização deve** reter **informação documentada** sobre o processo de avaliação de riscos da segurança da informação.
- A **organização** também **deve** estabelecer e aplicar um **processo de tratamento dos riscos** de SI, incluindo:

a) selecionar as **opções** apropriadas de **tratamento dos riscos** de SI, **levando-se em consideração os resultados da avaliação de riscos**;

b) determinar todos os **controles** necessários para **implementar** as **opções de tratamento** escolhidas;

c) comparar os controles determinados com aqueles do Anexo A, verificando possíveis omissões;

d) elaborar uma Declaração de Aplicabilidade que contenha: os controles necessários; a justificativa para inclusões; se os controles necessários são implementados ou não; e a justificativa para a exclusão de quaisquer controles do anexo A;

e) preparar um **plano para tratamento dos riscos** de SI;

f) obter a **aprovação dos responsáveis pelos riscos do plano** aqui destacado e a **aceitação dos riscos residuais** de SI.

- A **organização deve** reter a **informação documentada** relativa ao processo de tratamento de riscos de SI.

6.2. OBJETIVOS DA SEGURANÇA DA INFORMAÇÃO E PLANEJAMENTO PARA ALCANÇÁ-LOS

- A **organização deve** estabelecer os **objetivos de SI** para as funções e níveis relevantes.

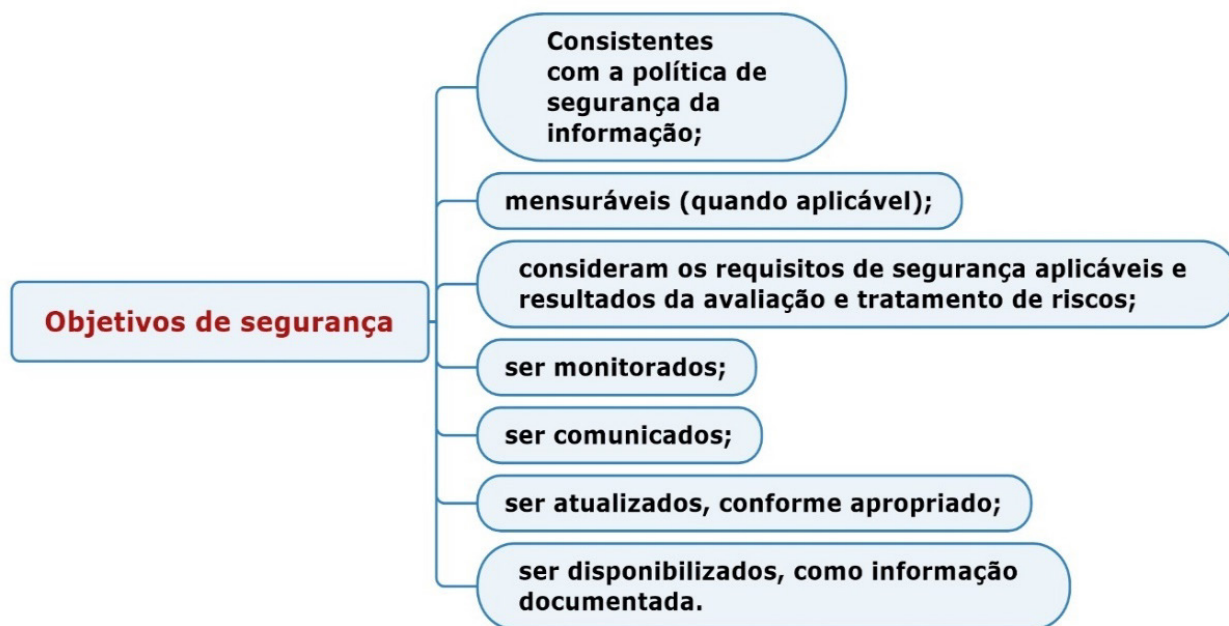


Figura. Objetivos de Segurança (QUINTÃO, 2024).

- A organização deve reter **informação documentada** dos objetivos de SI.
- Quando do planejamento para alcançar os seus **objetivos de SI**, a **organização deve** determinar **O QUE** será feito, **QUAIS** recursos serão necessários, **QUEM** será responsável, **QUANDO** estará concluído e **COMO** os resultados serão avaliados.

6.3. PLANEJAMENTO DE MUDANÇAS

- Quando a organização determina necessidade para as mudanças do **sistema de gestão da segurança da informação**, estas mudanças devem ser conduzidas de uma forma planejada.

7. APOIO

- A **organização deve**

a) determinar e prover **recursos** necessários para estabelecer, implementar, manter e melhorar continuamente o **SGSI**;

b) **determinar** a **competência** necessária da(s) pessoa(s) que realiza(m) o trabalho sob o seu controle que afete o desempenho da SI;

c) **assegurar** que essas pessoas sejam **competentes**, com base na **educação**, **treinamento** ou **experiência** apropriados;

d) **onde aplicável**, **tomar ações** para **adquirir a competência** necessária, avaliando a eficácia das ações tomadas;

e) reter **informação documentada** como evidência da competência.

- **Pessoas que realizam o trabalho** sob controle da organização **devem estar cientes da PSI**, da sua **contribuição** para a **eficácia** do **SGSI**, incluindo os benefícios da melhoria do desempenho da SI; e das **implicações da não conformidade** com os requisitos do **SGSI**.
- A **organização deve determinar** a necessidade de **comunicações** internas e externas **relevantes para o SGSI**, incluindo: **O QUE, QUANDO, QUEM será comunicado e COMO se comunicar**.
- O **SGSI deve incluir informação documentada requerida por esta norma e pela organização**.

NOTA: a **abrangência da informação documentada para o SGSI** pode variar, de acordo com: **tamanho da organização e seu tipo de atividades, processos, produtos e serviços; a complexidade dos processos e suas interações e a competência das pessoas**.

Nesse contexto, a organização deve assegurar de forma apropriada a **identificação, descrição** (por exemplo, título, data, autor ou um número de referência), **formato** (por exemplo, linguagem, versão do software, gráficos) **e seu meio** (por exemplo, papel, eletrônico), **análise crítica e aprovação para pertinência e adequação**.

Para o controle da informação documentada, devem ser consideradas as seguintes atividades, conforme aplicável: **distribuição, acesso, recuperação e uso; armazenamento e preservação**, incluindo a preservação da legibilidade; **controle de mudanças; e retenção e disposição**.

A **informação documentada de origem externa deve ser identificada** também **como apropriado, e controlada**.

8. OPERAÇÃO



Figura. Operação (QUINTÃO, 2024)

- Os resultados do tratamento de riscos de SI devem ser retidos como informação documentada pela organização.

9. AVALIAÇÃO DO DESEMPENHO

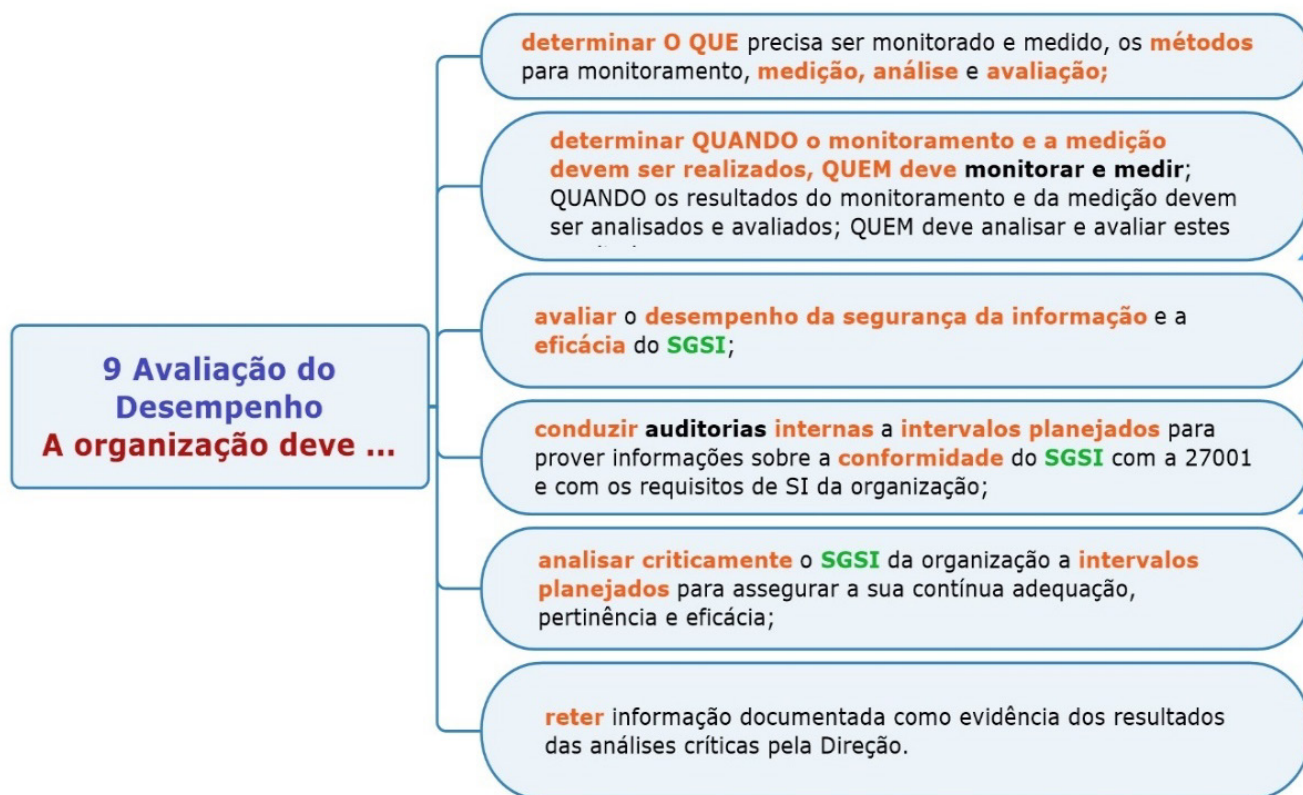


Figura. Avaliação de Desempenho (QUINTÃO, 2024).

Os resultados da análise crítica pela Direção devem incluir decisões relativas às oportunidades para melhoria contínua e quaisquer necessidades de mudanças do sistema de gestão de segurança da informação.

Informação documentada deve ser disponibilizada como evidência das **atividades críticas** pela Direção.

10. MELHORIA

10.1. MELHORIA CONTÍNUA

A **organização** deve **melhorar continuamente** a pertinência, adequação e eficácia do **SGSI**.

10.2. NÃO CONFORMIDADE E AÇÃO CORRETIVA

Ao detectar **não conformidades**, a **organização** deve:

- **reagir** e tomar ações para **controlar, corrigi-la e lidar com as consequências**;
- **avaliar** a necessidade de **ações** para **eliminar as causas**, para **evitar** que se repita ou ocorra;

- **implementar** quaisquer **ações** necessárias;
- **analisar criticamente** a eficácia das **ações corretivas** tomadas;
- realizar **mudanças** no **SGSI**, quando necessário.

A organização deve reter **informação documentada como evidência** da natureza das **não conformidades encontradas e quaisquer ações subsequentes tomadas**; e dos **resultados** de qualquer **ação** corretiva.

RESUMO



Figura. Dicas da Norma ABNT NBR ISO/IEC 27001:2022, versão corrigida 2023. (QUINTÃO, 2024)

Controles da Norma

5	Controles Organizacionais
5.1	Políticas de segurança da informação
5.2	Papéis e responsabilidades pela segurança da informação
5.3	Segregação de funções
5.4	Responsabilidades da direção
5.5	Contato com autoridades
5.6	Contato com grupos de interesse especial
5.7	Inteligência de ameaças
5.8	Segurança da informação no gerenciamento de projetos
5.9	Inventário de informações e outros ativos associados
5.10	Uso aceitável de informações e outros ativos associados
5.11	Devolução de ativos
5.12	Classificação das informações
5.13	Rotulagem de informações
5.14	Transferência de informações
5.15	Controle de acesso
5.16	Gestão de identidade
5.17	Informações de autenticação
5.18	Direitos de acesso
5.19	Segurança da informação nas relações com fornecedores
5.20	Abordagem da segurança da informação nos contratos de fornecedores
5.21	Gestão da segurança da informação na cadeia de fornecimento de TIC
5.22	Monitoramento, análise crítica e gestão de mudanças dos serviços de fornecedores
5.23	Segurança da informação para uso de serviços em nuvem
5.24	Planejamento e preparação da gestão de incidentes da segurança da informação
5.25	Avaliação e decisão sobre eventos da segurança da informação
5.26	Resposta a incidentes da segurança da informação
5.27	Aprendizado com incidentes de segurança da informação
5.28	Coleta de evidências
5.29	Segurança da informação durante a interrupção
5.30	Prontidão de TIC para continuidade de negócios
5.31	Requisitos legais, estatutários, regulamentares e contratuais
5.32	Direitos de propriedade intelectual
5.33	Proteção de registros

5.34	Privacidade e proteção de DP
5.35	Análise crítica independente da segurança da informação
5.36	<i>Compliance</i> com políticas, regras e normas para segurança da informação
5.37	Documentação dos procedimentos de operação

6	Controles de Pessoas
6.1	Seleção
6.2	Termos e condições de contratação
6.3	Conscientização, educação e treinamento em segurança da informação
6.4	Processo disciplinar
6.5	Responsabilidades após encerramento ou mudança da contratação
6.6	Acordos de confidencialidade ou não divulgação
6.7	Trabalho remoto
6.8	Relato de eventos de segurança da informação

7	Controles físicos
7.1	Perímetros de segurança física
7.2	Entrada física
7.3	Segurança de escritórios, salas e instalações
7.4	Monitoramento de segurança física
7.5	Proteção contra ameaças físicas e ambientais
7.6	Trabalho em áreas seguras
7.7	Mesa limpa e tela limpa
7.8	Localização e proteção de equipamentos
7.9	Segurança de ativos fora das instalações da organização
7.10	Mídia de armazenamento
7.11	Serviços de infraestrutura
7.12	Segurança do cabeamento
7.13	Manutenção de equipamentos
7.14	Descarte seguro ou reutilização de equipamentos

8	Controles tecnológicos
8.1	Dispositivos <i>endpoint</i> do usuário
8.2	Direitos de acessos privilegiados
8.3	Restrição de acesso à informação
8.4	Acesso ao código-fonte

8.5	Autenticação segura
8.6	Gestão de capacidade
8.7	Proteção contra <i>malware</i>
8.8.	Gestão de vulnerabilidades técnicas
8.9	Gestão de configuração
8.10	Exclusão de informações
8.11	Mascaramento de dados
8.12	Prevenção de vazamento de dados
8.13	<i>Backup</i> das informações
8.14	Redundância dos recursos de tratamento de informações
8.15	<i>Log</i>
8.16	Atividades de monitoramento
8.17	Sincronização do relógio
8.18	Uso de programas utilitários privilegiados
8.19	Instalação de <i>software</i> em sistemas operacionais
8.20	Segurança de redes
8.21	Segurança dos serviços de rede
8.22	Segregação de redes
8.23	Filtragem da <i>web</i>
8.24	Uso de criptografia
8.25	Ciclo de vida de desenvolvimento seguro
8.26	Requisitos de segurança da aplicação
8.27	Princípios de arquitetura e engenharia de sistemas seguros
8.28	Codificação segura
8.29	Testes de segurança em desenvolvimento e aceitação
8.30	Desenvolvimento terceirizado
8.31	Separação dos ambientes de desenvolvimento, teste e produção
8.32	Gestão de mudanças
8.33	Informações de teste
8.34	Proteção de sistemas de informação durante os testes de auditoria

Figura. 93 Controles da ISO 27001. Fonte: (QUINTÃO, 2023).

QUESTÕES COMENTADAS EM AULA

001. (CESPE/TJ-PA/ANALISTA JUDICIÁRIO – ANÁLISE DE SISTEMAS (DESENVOLVIMENTO)/2020/ADAPTADA) Conforme a NBR ISO/IEC 27001 [versão 2022, corrigida em 2023], implementar e operar um sistema de gestão de segurança da informação (SGSI) no processo PDCA envolve o requisito

- a) definir a abordagem de como será realizada a análise e avaliação dos riscos na organização.
- b) realizar a medição da eficácia dos controles estabelecidos no SGSI para verificar se estão atendidos.
- c) integrar os stakeholders na comunicação das ações de melhoria.
- d) elaborar o plano de tratamento dos riscos, identificando-se as ações de gestão apropriadas, os recursos a serem utilizados e as responsabilidades para a gestão dos riscos em segurança da informação.
- e) obter autorização da direção da organização para a implementação e operação do SGSI.

002. (INÉDITA/2023) A norma ISO/IEC 27001:2022, versão corrigida 2023, trata

- a) da gestão de riscos em sistemas de gestão da segurança da informação.
- b) de requisitos de sistema de gestão da segurança da informação, métricas e medidas, e diretrizes para implementação.
- c) de requisitos para auditoria e certificação de um sistema de gestão da segurança da informação.
- d) das recomendações de controles para segurança da informação da antiga ISO/IEC 17799.
- e) de requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação dentro do contexto da organização.

003. (CESPE/TCE-RO/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO – DESENVOLVIMENTO DE SISTEMAS/2019) De acordo com a NBR ISO/IEC n.º 27001:2022 [versão corrigida 2023], a alta direção de uma organização deve demonstrar liderança e comprometimento em relação ao sistema de gestão da segurança da informação. Para isso, ela deve

I assegurar que a política de segurança da informação seja compatível com a direção estratégica da organização.

II comunicar a importância da conformidade com os requisitos do sistema de gestão da segurança da informação.

III analisar criticamente os códigos quanto ao uso de técnicas de programação segura.

IV orientar pessoas que contribuam para a eficácia do sistema de gestão da segurança da informação.

Estão certos apenas os itens

- a) I e II.
- b) I e III.
- c) III e IV.
- d) I, II e IV.
- e) II, III e IV.

EXERCÍCIOS

004. (FGV/AUDITOR DE CONTROLE EXTERNO/TCE-PI/TECNOLOGIA DA INFORMAÇÃO/TECNOLOGIA DA INFORMAÇÃO/2025) De acordo com a NBR ISO/IEC 27001:2022, os controles de segurança da informação são agrupados em áreas de controles

- a) estruturais, pessoais, químicos e tecnológicos.
- b) organizacionais, pessoais, físicos e tecnológicos.
- c) estruturais, de recursos humanos, físicos e técnicos.
- d) organizacionais, de recursos humanos, físicos e químicos.
- e) organizacionais, estruturais, de recursos humanos e técnicos.

005. (FGV/AUDITOR DE CONTROLE EXTERNO (TCE-PI)/TECNOLOGIA DA INFORMAÇÃO/TECNOLOGIA DA INFORMAÇÃO/2025) A NBR ISO/IEC 27001:2022 fornece os requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão de segurança da informação (SGSI) no contexto da organização. Com relação às cláusulas e aos controles descritos nessa norma, analise as afirmativas a seguir.

- I. A organização deve determinar e fornecer os recursos necessários para o estabelecimento, implementação, manutenção e melhoria contínua de um SGSI.
- II. É obrigatório a implementação de todos os controles listados no Anexo A da norma.
- III. As cláusulas da referida norma estão divididas em contexto da organização, liderança, planejamento, implementação, suporte, operação, manutenção e conclusão.

Está correto o que se afirma em

- a) I, apenas.
- b) I e II, apenas.
- c) I e III, apenas.
- d) II e III, apenas.
- e) I, II e III.

006. (FGV/AUDITOR DE CONTROLE EXTERNO (TCE-PI)/TECNOLOGIA DA INFORMAÇÃO/TECNOLOGIA DA INFORMAÇÃO/2025) Os processos de gestão de riscos de um eficiente Sistema de Gestão de Segurança da Informação (SGSI) são bem definidos e podem ser enquadrados em uma das quatro fases do ciclo PDCA que são: planejamento, execução, verificação e ação. A fase de execução de um SGSI deve conter o processo de

- a) implementação do plano de tratamento de risco.
- b) monitoramento contínuo e análise crítica de riscos.
- c) melhoria do processo de gestão de riscos de segurança da informação.
- d) definição do plano de tratamento do risco.
- e) análise e execução de riscos.

007. (CEBRASPE (CESPE)/GESTOR DE APOIO ÀS ATIVIDADES POLICIAIS CIVIS (PC DF)/ANALISTA DE INFORMÁTICA/ANALISTA DE INFORMÁTICA/2025) Acerca da gestão de segurança da informação, de métodos de autenticação e de ameaças e vulnerabilidades em aplicações, julgue o item a seguir.

De acordo com a NBR ISO/IEC 27001, ao estabelecer o programa de auditoria interna, a organização deve desconsiderar resultados de auditorias anteriores para minimizar possíveis vieses, e sortear os auditores encarregados entre aqueles capacitados, de modo a evitar influências políticas no processo da auditoria interna.

008. (CEBRASPE (CESPE)/TÉCNICO (CAGEPA)/INFORMÁTICA/2024) De acordo com a norma ABNT NBR ISO/IEC 27001:2022, a classificação das informações está dentro do grupo de controles

- a) de acesso.
- b) tecnológicos.
- c) físicos.
- d) pessoais.
- e) organizacionais.

009. (CEBRASPE (CESPE)/TÉCNICO (CAGEPA)/INFORMÁTICA/2024) Conforme a ABNT NBR ISO/IEC 27001:2022, os atributos para tipo de controle são

- a) preventivo, detectivo e corretivo.
- b) identificar, proteger, detectar, responder e recuperar.
- c) governança, gestão de ativos, segurança física e continuidade.
- d) confidencialidade, integridade e disponibilidade.
- e) governança e ecossistema, proteção, defesa e resiliência.

010. (FGV/AUDITOR DE CONTROLE EXTERNO (TCE-PA)/ADMINISTRATIVA/CIÊNCIA DE DADOS/2024) Para assegurar que o SGSI esteja em conformidade com a norma ABNT NBR ISO/IEC 27001:2022, a organização deve

- a) focar na tecnologia, sem considerar o contexto da organização.
- b) envolver a alta administração e definir políticas claras de segurança da informação.
- c) implementar controles de segurança sem a necessidade de avaliação de riscos.
- d) evitar o monitoramento contínuo e a avaliação de desempenho do SGSI.
- e) ignorar a necessidade de melhorias contínuas após a implementação inicial.

011. (FCC/TÉCNICO JUDICIÁRIO (TRT 15ª REGIÃO)/APOIO ESPECIALIZADO/TECNOLOGIA DA INFORMAÇÃO/2023) Dentre os controles de segurança da informação referenciados na norma ABNT NBR ISO/IEC 27001:2022 está o que recomenda que

- a) papéis e responsabilidades pela segurança da informação devem ser definidos e alocados de acordo com os interesses dos setores operacionais.
- b) funções conflitantes e áreas de responsabilidade conflitantes devem ser segregadas
- c) medidas de segurança devem ser implementadas somente para o trabalho presencial.
- d) os ativos fora das instalações da organização não precisam ser protegidos.

012. (FGV/ANALISTA JUDICIÁRIO (TRF 1ª REGIÃO)/APOIO ESPECIALIZADO/GOVERNANÇA E GESTÃO DE TECNOLOGIA DA INFORMAÇÃO/2024) A Norma ABNT NBR ISO/IEC 27001:2022 recomenda que as organizações estabeleçam e apliquem um processo de tratamento de riscos de segurança da informação para:

- a) preparar um plano diretor de tecnologia da informação;
- b) obter da alta gestão a aprovação dos riscos do plano de tratamento de riscos;
- c) elaborar uma declaração de aplicabilidade que contenha os controles avançados de segurança da informação;
- d) determinar os controles que são necessários para implementar as opções escolhidas do tratamento de riscos de segurança da informação;
- e) selecionar, de forma apropriada, as opções de tratamento dos riscos da segurança da informação levando em consideração os requisitos da alta gestão.

013. (CESGRANRIO/ANALISTA (BNDES)/ANÁLISE DE SISTEMA/ CIBERSEGURANÇA/2024) Um Sistema de Gestão da Segurança da Informação (SGSI) deve ser integrado aos processos da organização e à estrutura de administração global para que a segurança da informação seja considerada no projeto dos processos, sistemas de informação e controles.

A organização deve melhorar continuamente a pertinência, a adequação e a eficácia do SGSI. A norma ABNT NBR ISO/IEC 27001:2022 define vários itens que fazem parte da melhoria do SGSI. Dentre esses itens, encontra-se a(o)

- a) auditoria interna
- b) análise crítica pela direção
- c) não conformidade e ação corretiva
- d) monitoramento, a medição, a análise e a avaliação
- e) tratamento de riscos de segurança da informação

014. (VUNESP/AUDITOR-FISCAL TRIBUTÁRIO MUNICIPAL (PREF SP)/TECNOLOGIA DA INFORMAÇÃO/2023) A norma ABNT NBR ISO/IEC 27001:2022 (Segurança da informação, segurança cibernética e proteção à privacidade – Sistemas de gestão da segurança da informação – Requisitos) estabelece condições para os objetivos da segurança da informação, sendo correto afirmar que tal norma define que:

- a) esses objetivos devem ser mensuráveis (se praticável) e monitorados.

- b) esses objetivos são estabelecidos em um pré-projeto e não mais atualizados.
- c) dentre tais objetivos, encontra-se a necessidade de contar com equipes experientes.
- d) não há necessidade de documentar tais objetivos, visto que não mais poderão ocorrer após a validação do sistema.
- e) dentre tais objetivos, fica estabelecido um tempo máximo para a eliminação dos riscos de segurança.

015. (CESPE/TJ-AM/ANALISTA JUDICIÁRIO – ANALISTA DE SISTEMAS/2019/ADAPTADA) Julgue o próximo item, relativo à gestão de segurança da informação.

De acordo com a norma NBR ISO/IEC 27001 [de 2022, Versão corrigida 2023], uma organização que vise estabelecer um sistema de gestão de segurança da informação (SGSI) deve entender o contexto interno e externo da organização em relação aos riscos e aplicar um processo de avaliação de riscos de segurança da informação e uma análise qualitativa e quantitativa.

016. (CESPE/TCE-RN/ASSESSOR TÉCNICO DE INFORMÁTICA – CONTROLE EXTERNO/2015/ADAPTADA) Julgue os itens a seguir, acerca de gestão de segurança da informação à luz das normas ISO/IEC 27001 (de 2022) e 27002.

Se, para manutenção de máquinas de uma organização é necessário eliminar quaisquer dados sensíveis das máquinas antes de serem manipuladas por pessoal externo à organização, diz-se que esse controle refere-se ao domínio de controles físicos.

017. (CESPE/TCE RN/ASSESSOR TÉCNICO DE INFORMÁTICA/CONTROLE EXTERNO/2015) Julgue os itens a seguir, acerca de gestão de segurança da informação à luz das normas ISO/IEC 27001 e 27002. A política de segurança deve ser aprovada pelo gestor máximo da instituição, assinada pelo chefe da informática, e divulgada para o pessoal de tecnologia da informação e comunicação (TIC).

018. (CESPE/TCE-RN/ASSESSOR TÉCNICO DE INFORMÁTICA/CONTROLE EXTERNO/2015) Julgue os itens a seguir, acerca de gestão de segurança da informação à luz das normas ISO/IEC 27001 e 27002.

Um dos objetivos das auditorias internas do SGSI é determinar se seus controles são executados conforme esperado.

019. (CESPE/MCT/TECNOLOGISTA PLENO/SEGURANÇA DE SISTEMAS DE INFORMAÇÃO/ADAPTADA/2008) Uma organização que deseje implantar um sistema de gestão de segurança da informação (SGSI) deve adotar como base a norma ABNT NBR ISO/IEC 27001:2022

020. (INÉDITA/2024) A seção 4.3 da norma ISO/IEC 27001:2022 (versão corrigida 2023) trata os itens que a organização deve considerar quando da determinação do escopo.

021. (CESPE/INMETRO/PESQUISADOR/CIÊNCIA DA COMPUTAÇÃO/2010) Com relação aos controles recomendados nas normas 27001 e 27002, é correto destacar que todos os controles que constam da norma devem ser implementados.

022. (CESPE/INMETRO – PESQUISADOR – CIÊNCIA DA COMPUTAÇÃO/2010) Com relação aos controles recomendados nas normas ISO/IEC 27001 e ISO/IEC 27002, é correto destacar que a implementação dos controles permite garantir a segurança da informação.

023. (CESPE/INMETRO – PESQUISADOR – CIÊNCIA DA COMPUTAÇÃO/2010) Com relação aos controles recomendados nas normas 27001 e 27002, é correto destacar que a norma 27001 define os controles que devem ser implementados.

024. (CESPE/INMETRO – PESQUISADOR – CIÊNCIA DA COMPUTAÇÃO/2010) Com relação aos controles recomendados nas normas 27001 e 27002, é correto destacar que a norma 27002 define os requisitos de um sistema de gestão de segurança da informação.

025. (CESPE/TCU/ANALISTA DE CONTROLE EXTERNO/TI/2007) A ISO 17799 define diretrizes para certificação de que uma organização está em conformidade à própria norma. Essa certificação é conferida por meio de uma auditoria de terceira parte, nos moldes da ISO 19011.

026. (CESPE/BANCO DA AMAZÔNIA/TÉCNICO CIENTÍFICO – ESPECIALIDADE: TECNOLOGIA DA INFORMAÇÃO/SEGURANÇA DA INFORMAÇÃO/2010) São exemplos de ativos de uma organização a informação e os processos de apoio, sistemas e redes. Os requisitos de segurança, em uma organização, são identificados por meio de análise sistemática dos riscos de segurança.

027. (FGV/MPE-AL/ANALISTA DO MINISTÉRIO PÚBLICO – DESENVOLVIMENTO DE SISTEMAS/2018) Assinale a opção que melhor descreve o princípio geral da norma ISO/IEC 27001.

- a) Definir os procedimentos e tarefas adequados à mitigação de riscos no âmbito de um sistema de gestão de segurança da informação.
- b) Definir os requisitos necessários para estabelecer, implementar, manter e melhorar de forma contínua um sistema de gestão de segurança da informação.
- c) Estabelecer os papéis, responsabilidades e atuação dos profissionais de segurança da informação numa organização.
- d) Orientar e alertar as organizações e seus respectivos profissionais em diversos aspectos relativos à gestão de segurança da informação.
- e) Prover uma coleção de artefatos tecnológicos que permitam a identificação, avaliação e eliminação de ataques aos ativos de segurança da informação.

028. (FCC/MPE-PE/ANALISTA MINISTERIAL/INFORMÁTICA/2018/ADAPTADA) Dentre os controles mencionados no Anexo A da norma NBR ISO/IEC 27001:2022 está: “Todos os funcionários da organização e, onde pertinente, as partes externas devem receber treinamento, educação e conscientização apropriados, e as atualizações regulares das políticas e procedimentos organizacionais relevantes para as suas funções.” Este controle é parte do domínio:

- a) Segurança nas operações.
- b) Política de segurança da informação.
- c) Controles de pessoas.
- d) Organização da segurança da informação.
- e) Segurança física e do ambiente.

029. (FCC/ARTESP/ESPECIALISTA EM REGULAÇÃO DE TRANSPORTE I/TECNOLOGIA DA INFORMAÇÃO/2017) Uma organização deve determinar e prover recursos necessários para o estabelecimento, implementação, manutenção e melhoria contínua da gestão da segurança da informação. Dentre esses recursos estão as pessoas que realizam o trabalho sob o controle da organização. Segundo a norma ABNT NBR ISO/IEC 27001:2022, todas estas pessoas devem estar cientes

- a) do plano de continuidade de negócios e de suas responsabilidades e papéis, já que todos participam quando é necessário colocar este plano em prática.
- b) do plano estratégico, que estabelece a direção a ser seguida pela organização para melhorar o sistema de gestão da segurança da informação.
- c) do plano operacional, que define as ações e metas traçadas para atingir os objetivos das decisões estratégicas relacionadas à segurança da informação.
- d) de suas responsabilidades no processo de gestão de riscos de segurança da informação, atuando como observadoras das ações dos demais funcionários na identificação de potenciais riscos de segurança da informação.
- e) das implicações da não conformidade com os requisitos do sistema de gestão da segurança da informação.

030. (FGV/DPE-RJ/TÉCNICO SUPERIOR ESPECIALIZADO/SEGURANÇA DA INFORMAÇÃO/2014) Uma instituição pretende implantar um sistema de gestão da segurança da informação. Para isso, ela deve seguir as orientações da norma:

- a) ISO 27001.
- b) ISO 27002.
- c) ISO 27005.
- d) ISO 27006.
- e) ISO 27010.

031. (ESAF/MPOG/ANALISTA DE PLANEJAMENTO E ORÇAMENTO-APO-TI/2008) A segurança da informação tem como objetivo a preservação da

- a) confidencialidade, interatividade e acessibilidade informações.
- b) complexidade, integridade e disponibilidade das informações.
- c) confidencialidade, integridade e acessibilidade das informações.
- d) universalidade, interatividade e disponibilidade das informações.
- e) confidencialidade, integridade e disponibilidade das informações.

032. (FCC/INFRAERO/ANALISTA/SEGURANÇA DA INFORMAÇÃO/2011/ADAPTADA) Sobre a norma ABNT NBR ISO/IEC 27001:2022, é INCORRETO afirmar:

- a) Promove a adoção de uma abordagem de processo para estabelecer e implementar, operar, monitorar, analisar criticamente, manter e melhorar o SGSI de uma organização.
- b) Foi desenvolvida para organizações privadas e seus requisitos genéricos não são aplicáveis às organizações públicas ou privadas de pequeno porte.
- c) Especifica os requisitos para estabelecer, implementar, operar, monitorar, analisar criticamente, manter e melhorar um SGSI documentado dentro do contexto dos riscos de negócio globais da organização.
- d) Especifica requisitos para a implementação de controles de segurança personalizados para as necessidades individuais de organizações ou suas partes.

033. (FUMARC/PRODEMGE/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO/2011) A norma ISO/IEC 27001 foi elaborada para prover um modelo de sistema de gestão de segurança da informação (SGSI) e também para avaliar a conformidade deste pelas partes interessadas internas e externas.

034. (FCC/TRE-RR/ANALISTA JUDICIÁRIO/ANÁLISE DE SISTEMAS/2015) Considere que um determinado Tribunal Regional Eleitoral esteja definindo uma forma de gerenciar riscos da infraestrutura de TI, incluindo a determinação de políticas, procedimentos, diretrizes, práticas e estruturas organizacionais para estabelecer proteções e contramedidas. De acordo com a Norma ISO/IEC 27002, essa definição para segurança da informação é denominada

- a) Ativo
- b) Evento
- c) Controle
- d) Recurso
- e) Política

GABARITO

1. b
2. a
3. a
4. E
5. d
6. e
7. d
8. e
9. a
10. b
11. b
12. d
13. c
14. a
15. C
16. C
17. E
18. C
19. C
20. C
21. E
22. E
23. E
24. E
25. E
26. C
27. b
28. c
29. e
30. a
31. e
32. b
33. C
34. c

GABARITO COMENTADO

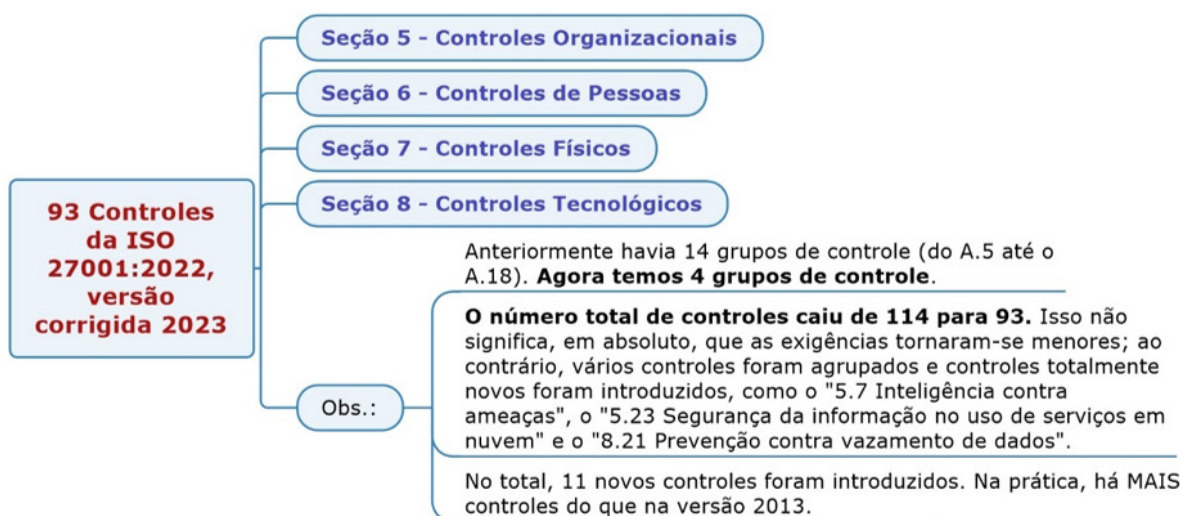
004. (FGV/AUDITOR DE CONTROLE EXTERNO/TCE-PI/TECNOLOGIA DA INFORMAÇÃO/TECNOLOGIA DA INFORMAÇÃO/2025) De acordo com a NBR ISO/IEC 27001:2022, os controles de segurança da informação são agrupados em áreas de controles

- a) estruturais, pessoais, químicos e tecnológicos.
- b) organizacionais, pessoais, físicos e tecnológicos.
- c) estruturais, de recursos humanos, físicos e técnicos.
- d) organizacionais, de recursos humanos, físicos e químicos.
- e) organizacionais, estruturais, de recursos humanos e técnicos.



Os controles são organizados em quatro domínios, que são:

- Controles **organizacionais** (37 controles)
- Controles **de pessoas** (8 controles)
- Controles **físicos** (14 controles)
- Controles **tecnológicos** (34 controles)



Letra b.

005. (FGV/AUDITOR DE CONTROLE EXTERNO (TCE-PI)/TECNOLOGIA DA INFORMAÇÃO/TECNOLOGIA DA INFORMAÇÃO/2025) A NBR ISO/IEC 27001:2022 fornece os requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão de segurança da informação (SGSI) no contexto da organização. Com relação às cláusulas e aos controles descritos nessa norma, analise as afirmativas a seguir.

I. A organização deve determinar e fornecer os recursos necessários para o estabelecimento, implementação, manutenção e melhoria contínua de um SGSI.

II. É obrigatório a implementação de todos os controles listados no Anexo A da norma.

III. As cláusulas da referida norma estão divididas em contexto da organização, liderança, planejamento, implementação, suporte, operação, manutenção e conclusão.

Está correto o que se afirma em

- a) I, apenas.
- b) I e II, apenas.
- c) I e III, apenas.
- d) II e III, apenas.
- e) I, II e III.



I. Certa. A norma NBR ISO/IEC 27001:2022 exige que a organização identifique e forneça os recursos adequados para a implementação eficaz de um Sistema de Gestão de Segurança da Informação (SGSI). Isso está alinhado às cláusulas gerais da norma, especificamente na seção sobre planejamento e recursos.

Conforme a **NBR ISO/IEC 27001:2022**:

A organização deve determinar e prover recursos necessários para estabelecer, implementar, manter e melhorar continuamente o sistema de gestão da segurança da informação.

II. Errada. O Anexo A da ISO/IEC 27001:2022 fornece uma lista de controles que podem ou **não** ser aplicáveis dependendo do contexto da organização. A norma não obriga a implementação de todos os controles descritos no Anexo A. A organização deve realizar uma **análise de riscos** para determinar quais controles são aplicáveis e apropriados às suas necessidades.

Segundo a NBR ISO/IEC 27001:2022:

A organização deve estabelecer e aplicar um processo de tratamento de riscos da segurança da informação para:

- a) **selecionar, de forma apropriada, as opções de tratamento dos riscos da segurança da informação, levando em consideração os resultados da avaliação de riscos;**
- b) **determinar todos os controles que são necessários para implementar as opções escolhidas do tratamento de riscos da segurança da informação;**

III. Errada. A estrutura da NBR ISO/IEC 27001:2022 organiza as cláusulas em tópicos como:

- **Contexto da organização** (cláusula 4);
- **Liderança** (cláusula 5);
- **Planejamento** (cláusula 6);
- **Apoio** (cláusula 7);
- **Operação** (cláusula 8);

- **Avaliação de desempenho** (cláusula 9);
- **Melhoria** (cláusula 10).

Porém, não existe uma divisão explícita em “implementação”, “manutenção” e “conclusão”. Esses termos não fazem parte das cláusulas gerais da norma, tornando a afirmação incorreta. A única afirmativa correta é a I, portanto a alternativa correta é a A) I, apenas.

Letra a.

006. (FGV/AUDITOR DE CONTROLE EXTERNO (TCE-PI)/TECNOLOGIA DA INFORMAÇÃO/TECNOLOGIA DA INFORMAÇÃO/2025) Os processos de gestão de riscos de um eficiente Sistema de Gestão de Segurança da Informação (SGSI) são bem definidos e podem ser enquadrados em uma das quatro fases do ciclo PDCA que são: planejamento, execução, verificação e ação. A fase de execução de um SGSI deve conter o processo de

- a) implementação do plano de tratamento de risco.
- b) monitoramento contínuo e análise crítica de riscos.
- c) melhoria do processo de gestão de riscos de segurança da informação.
- d) definição do plano de tratamento do risco.
- e) análise e execução de riscos.



O **ciclo PDCA (Planejar, Fazer, Checar, Agir)** é um modelo amplamente utilizado para a implementação de sistemas de gestão, incluindo o **Sistema de Gestão de Segurança da Informação (SGSI)**, conforme NBR ISO/IEC 27001.

Cada fase do PDCA envolve processos específicos para a gestão de riscos. Esses processos são destacados a seguir:

- **Planejar (Plan):**
 - Identificar ativos, ameaças e vulnerabilidades.
 - Avaliar riscos.
 - Desenvolver e definir o plano de tratamento de riscos.
 - A elaboração do plano para lidar com os riscos ocorre nesta etapa.
- **Executar (Do):**
 - Nesta fase, ocorre a **implementação do plano de tratamento de risco** elaborado na etapa de planejamento.
 - São aplicados os controles de segurança definidos para mitigar os riscos identificados.
- **Checar (Check):**
 - Realizar o monitoramento contínuo, auditorias e análises críticas para avaliar a eficácia dos planos implementados.
 - Essa etapa inclui o **monitoramento contínuo e análise crítica de riscos**.

• **Agir (Act):**

- Realizar ações corretivas e preventivas com base nos resultados das auditorias e análises.
- Consiste na **melhoria contínua** do processo de gestão de riscos e do SGSI.

a) Certa. **Implementação do plano de tratamento de risco.** Relaciona-se diretamente à fase de **execução (Do)**, em que os controles e estratégias planejados são colocados em prática.

b) Errada. **Monitoramento contínuo e análise crítica de riscos.** Essa atividade ocorre na fase de **checar (Check)**, não na fase de execução.

c) Errada. **Melhoria do processo de gestão de riscos de segurança da informação.** Essa atividade está relacionada à fase de **agir (Act)**, focada em melhorias contínuas.

d) Errada. **Definição do plano de tratamento do risco.** O processo de definição do plano ocorre na fase de **planejamento (Plan)**.

e) Errada. **Análise e execução de riscos.** Essa descrição está incorreta e imprecisa, pois não reflete nenhuma fase do ciclo PDCA formalmente.

Conforme visto, a fase de execução (Do) no ciclo PDCA envolve a **implementação do plano de tratamento de risco**, tornando a alternativa A a correta.

Letra a.

007. (CEBRASPE (CESPE)/GESTOR DE APOIO ÀS ATIVIDADES POLICIAIS CIVIS (PC DF)/ANALISTA DE INFORMÁTICA/ANALISTA DE INFORMÁTICA/2025) Acerca da gestão de segurança da informação, de métodos de autenticação e de ameaças e vulnerabilidades em aplicações, julgue o item a seguir.

De acordo com a NBR ISO/IEC 27001, ao estabelecer o programa de auditoria interna, a organização deve desconsiderar resultados de auditorias anteriores para minimizar possíveis vieses, e sortear os auditores encarregados entre aqueles capacitados, de modo a evitar influências políticas no processo da auditoria interna.



A NBR ISO/IEC 27001 estabelece diretrizes e requisitos para a gestão da segurança da informação, incluindo processos de auditoria interna. No entanto, a norma não recomenda desconsiderar os resultados de auditorias anteriores. **Pelo contrário, os resultados de auditorias anteriores são essenciais e devem ser levados em consideração ao planejar o programa de auditoria interna.** Isso porque eles fornecem informações importantes sobre não conformidades identificadas anteriormente, áreas de maior risco e oportunidades de melhoria.

Além disso, a norma exige que os auditores sejam **imparciais, competentes e independentes do objeto da auditoria**, mas não menciona que os auditores devam ser sorteados. A seleção

dos auditores deve ser feita com base em critérios de **competência e independência**, visando a eficácia do processo e não utilizando sorteio como método.

Portanto, o trecho do item contradiz as práticas recomendadas pela norma ISO/IEC 27001.

O item está errado porque:

- a norma exige a consideração dos resultados de auditorias anteriores no planejamento do programa de auditorias internas;
- não há recomendação ou exigência de sorteio para a escolha dos auditores; eles devem ser selecionados com base em critérios objetivos, como competência e independência.

Errado.

008. (CEBRASPE (CESPE)/TÉCNICO (CAGEPA)/INFORMÁTICA/2024) De acordo com a norma ABNT NBR ISO/IEC 27001:2022, a classificação das informações está dentro do grupo de controles

- de acesso.
- tecnológicos.
- físicos.
- pessoais.
- organizacionais.



De acordo com a norma ABNT NBR ISO/IEC 27001:2022, a classificação das informações está dentro do **grupo de controles:**

e) organizacionais.

A classificação das informações é parte dos controles organizacionais, pois envolve estabelecer políticas e procedimentos para garantir que as informações sejam tratadas conforme seu nível de sensibilidade e importância para a organização. Veja os controles desse grupo:

5	Controles Organizacionais
5.1	Políticas de segurança da informação
5.2	Papéis e responsabilidades pela segurança da informação
5.3	Segregação de funções
5.4	Responsabilidades da direção
5.5	Contato com autoridades
5.6	Contato com grupos de interesse especial
5.7	Inteligência de ameaças
5.8	Segurança da informação no gerenciamento de projetos
5.9	Inventário de informações e outros ativos associados

5.10	Uso aceitável de informações e outros ativos associados
5.11	Devolução de ativos
5.12	Classificação das informações
5.13	Rotulagem de informações
5.14	Transferência de informações
5.15	Controle de acesso
5.16	Gestão de identidade
5.17	Informações de autenticação
5.18	Direitos de acesso
5.19	Segurança da informação nas relações com fornecedores
5.20	Abordagem da segurança da informação nos contratos de fornecedores
5.21	Gestão da segurança da informação na cadeia de fornecimento de TIC
5.22	Monitoramento, análise crítica e gestão de mudanças dos serviços de fornecedores
5.23	Segurança da informação para uso de serviços em nuvem
5.24	Planejamento e preparação da gestão de incidentes da segurança da informação
5.25	Avaliação e decisão sobre eventos da segurança da informação
5.26	Resposta a incidentes da segurança da informação
5.27	Aprendizado com incidentes de segurança da informação
5.28	Coleta de evidências
5.29	Segurança da informação durante a interrupção
5.30	Prontidão de TIC para continuidade de negócios
5.31	Requisitos legais, estatutários, regulamentares e contratuais
5.32	Direitos de propriedade intelectual
5.33	Proteção de registros
5.34	Privacidade e proteção de DP
5.35	Análise crítica independente da segurança da informação
5.36	Compliance com políticas, regras e normas para segurança da informação
5.37	Documentação dos procedimentos de operação

Letra e.

009. (CEBRASPE (CESPE)/TÉCNICO (CAGEPA)/INFORMÁTICA/2024) Conforme a ABNT NBR ISO/IEC 27001:2022, os atributos para tipo de controle são

- a) preventivo, detectivo e corretivo.
- b) identificar, proteger, detectar, responder e recuperar.
- c) governança, gestão de ativos, segurança física e continuidade.

- d) confidencialidade, integridade e disponibilidade.
- e) governança e ecossistema, proteção, defesa e resiliência.



Os atributos para tipo de controle são: **a) preventivo, detectivo e corretivo.**

Embora a norma em si se concentre em um sistema de gestão de segurança da informação abrangente, o detalhamento específico desses tipos de controle é geralmente mais associado à norma ISO/IEC 27002, que complementa a 27001 com diretrizes sobre a implementação de controles de segurança.

O **tipo de controle** é um atributo para visualizar controles sob a perspectiva de quando e como o controle modifica o risco em relação à ocorrência de um incidente de segurança da informação.

Os valores de atributo destacados na ABNT NBR ISO/IEC 27002 consistem em:

- **Preventivo** (o controle que se destina a evitar a ocorrência de um incidente de segurança da informação);
- **Detectivo** (o controle age quando ocorre um incidente de segurança da informação); e
- **Corretivo** (o controle age após um incidente de segurança da informação ocorrer).

Letra a.

010. (FGV/AUDITOR DE CONTROLE EXTERNO (TCE-PA)/ADMINISTRATIVA/CIÊNCIA DE DADOS/2024) Para assegurar que o SGSI esteja em conformidade com a norma ABNT NBR ISO/IEC 27001:2022, a organização deve

- a) focar na tecnologia, sem considerar o contexto da organização.
- b) envolver a alta administração e definir políticas claras de segurança da informação.
- c) implementar controles de segurança sem a necessidade de avaliação de riscos.
- d) evitar o monitoramento contínuo e a avaliação de desempenho do SGSI.
- e) ignorar a necessidade de melhorias contínuas após a implementação inicial.



Vamos detalhar cada uma das assertivas em relação à conformidade com a norma ABNT NBR ISO/IEC 27001:2022:

- a) Errada. A norma enfatiza a importância de entender o contexto da organização, incluindo fatores internos e externos que podem impactar o SGSI. Focar apenas na tecnologia ignora aspectos críticos como política organizacional, cultura, estrutura e processos, que são essenciais para uma implementação eficaz do SGSI.
- b) Certa. A norma requer o envolvimento da alta administração para assegurar que o SGSI esteja alinhado com os objetivos estratégicos da organização. A definição de políticas claras de segurança da informação é crucial para estabelecer expectativas, responsabilidades e orientar a implementação e operação do SGSI.

c) Errada. A norma exige que a implementação de controles de segurança seja baseada em uma avaliação de riscos. Isso garante que os controles sejam apropriados e eficazes para mitigar os riscos identificados, evitando a implementação de medidas desnecessárias ou inadequadas.

d) Errada. A norma requer monitoramento contínuo e avaliação regular do desempenho do SGSI para garantir sua eficácia e identificar áreas para melhoria. O monitoramento contínuo permite que a organização responda rapidamente a mudanças no ambiente de risco e mantenha a conformidade com os requisitos normativos.

e) Errada. A norma enfatiza a importância da melhoria contínua como parte do ciclo PDCA (Plan-Do-Check-Act) para assegurar que o SGSI permaneça eficaz e relevante em face de novas ameaças, mudanças organizacionais e avanços tecnológicos.

Em resumo, a conformidade com a ABNT NBR ISO/IEC 27001:2022 requer uma abordagem abrangente que envolve a alta administração, avaliação de riscos, monitoramento contínuo e um compromisso com a melhoria contínua.

Letra b.

011. (FCC/TÉCNICO JUDICIÁRIO (TRT 15ª REGIÃO)/APOIO ESPECIALIZADO/TECNOLOGIA DA INFORMAÇÃO/2023) Dentre os controles de segurança da informação referenciados na norma ABNT NBR ISO/IEC 27001:2022 está o que recomenda que

- a) papéis e responsabilidades pela segurança da informação devem ser definidos e alocados de acordo com os interesses dos setores operacionais.
- b) funções conflitantes e áreas de responsabilidade conflitantes devem ser segregadas
- c) medidas de segurança devem ser implementadas somente para o trabalho presencial.
- d) os ativos fora das instalações da organização não precisam ser protegidos.



Conforme a norma ABNT NBR ISO/IEC 27001:2022:

a) Errada. Embora seja importante considerar os setores operacionais ao definir papéis e responsabilidades, a norma enfatiza que esses devem ser definidos com base nas necessidades de segurança da informação da organização como um todo, não apenas nos interesses de setores específicos. A alocação deve garantir que todos os aspectos da segurança da informação sejam cobertos de forma eficaz e que haja clareza sobre quem é responsável por cada área.

b) Certa. Esta é uma prática recomendada pela norma. A segregação de funções é um controle fundamental para prevenir conflitos de interesse, fraudes e erros. Ao separar funções conflitantes, a organização pode assegurar que nenhuma pessoa ou equipe tenha controle absoluto sobre todas as partes de um processo crítico, promovendo assim uma supervisão e controle mais eficazes.

c) Errada. As medidas de segurança devem ser implementadas para proteger informações em todos os ambientes de trabalho, incluindo remoto, híbrido e presencial. Com o aumento do trabalho remoto, é crucial que as organizações tenham controles adequados para proteger dados e sistemas acessados fora das instalações físicas da organização.

d) Errada. A norma destaca a importância de proteger todos os ativos de informação, independentemente de sua localização. Isso inclui ativos fora das instalações da organização, como dispositivos móveis, laptops e dados armazenados em nuvem. Proteger esses ativos é essencial para prevenir perdas, acessos não autorizados e outros riscos de segurança.

Em resumo, a norma ABNT NBR ISO/IEC 27001:2022 promove uma abordagem abrangente à segurança da informação, que inclui a definição clara de papéis e responsabilidades, a segregação de funções conflitantes, e a proteção de ativos em todas as formas de trabalho e localizações.

Letra b.

012. (FGV/ANALISTA JUDICIÁRIO (TRF 1ª REGIÃO)/APOIO ESPECIALIZADO/GOVERNANÇA E GESTÃO DE TECNOLOGIA DA INFORMAÇÃO/2024) A Norma ABNT NBR ISO/IEC 27001:2022 recomenda que as organizações estabeleçam e apliquem um processo de tratamento de riscos de segurança da informação para:

- a) preparar um plano diretor de tecnologia da informação;
- b) obter da alta gestão a aprovação dos riscos do plano de tratamento de riscos;
- c) elaborar uma declaração de aplicabilidade que contenha os controles avançados de segurança da informação;
- d) determinar os controles que são necessários para implementar as opções escolhidas do tratamento de riscos de segurança da informação;
- e) selecionar, de forma apropriada, as opções de tratamento dos riscos da segurança da informação levando em consideração os requisitos da alta gestão.



Vamos explorar cada uma das assertivas relacionadas ao processo de tratamento de riscos de segurança da informação conforme a norma ABNT NBR ISO/IEC 27001:2022:

a) Errada Esta assertiva não está diretamente relacionada ao processo de tratamento de riscos de segurança da informação conforme descrito na norma. Um plano diretor de tecnologia da informação é um documento estratégico que define a direção e as prioridades para a tecnologia da informação na organização, abrangendo metas, recursos e cronogramas, mas não é especificamente parte do processo de tratamento de riscos de segurança da informação.

b) Errada. Em 6.1.3.f a norma cita “obter a **aprovação dos responsáveis pelos riscos do plano** aqui destacado e a **aceitação dos riscos residuais** de SI.

c) Errada A elaboração de uma declaração de aplicabilidade é um requisito da norma, mas ela não necessariamente contém “controles avançados”. A declaração de aplicabilidade deve listar todos os controles de segurança que foram considerados necessários para tratar os riscos identificados, justificando a sua inclusão ou exclusão. É um documento essencial que vincula os riscos aos controles implementados.

Elaborar uma Declaração de Aplicabilidade que contenha: os controles necessários; a justificativa para inclusões; se os controles necessários são implementados ou não; e a justificativa para a exclusão de quaisquer controles do anexo A.

d) Certa. O processo de tratamento de riscos envolve a determinação dos controles necessários para implementar as opções de tratamento selecionadas. Isso significa escolher medidas apropriadas para mitigar, transferir, aceitar ou evitar riscos, conforme identificado na avaliação de riscos.

e) Errada. Selecionar as **opções** apropriadas de **tratamento dos riscos** de SI, **levando-se em consideração os resultados da avaliação de riscos**.

Letra d.

013. (CESGRANRIO/ANALISTA (BNDES)/ANÁLISE DE SISTEMA/ CIBERSEGURANÇA/2024) Um Sistema de Gestão da Segurança da Informação (SGSI) deve ser integrado aos processos da organização e à estrutura de administração global para que a segurança da informação seja considerada no projeto dos processos, sistemas de informação e controles.

A organização deve melhorar continuamente a pertinência, a adequação e a eficácia do SGSI. A norma ABNT NBR ISO/IEC 27001:2022 define vários itens que fazem parte da melhoria do SGSI. Dentre esses itens, encontra-se a(o)

- a) auditoria interna
- b) análise crítica pela direção
- c) não conformidade e ação corretiva
- d) monitoramento, a medição, a análise e a avaliação
- e) tratamento de riscos de segurança da informação



Veja os itens da seção 10 – Melhoria:

10.1. Melhoria Contínua

A **organização** deve **melhorar continuamente** a pertinência, adequação e eficácia do **SGSI**.

10.2. Não conformidade e Ação Corretiva

Ao detectar **não conformidades**, a **organização** deve:

- **reagir** e tomar ações para **controlar, corrigi-la e lidar com as consequências**;

- **avaliar** a necessidade de **ações** para **eliminar as causas**, para **evitar** que se repita ou ocorra;
- **implementar** quaisquer **ações** necessárias;
- **analisar criticamente** a eficácia das **ações corretivas** tomadas;
- realizar **mudanças** no **SGSI**, quando necessário.

[...]

Conforme visto, na seção 10 da norma ABNT NBR ISO/IEC 27001:2022, que trata da melhoria contínua do SGSI, um dos itens específicos mencionados é a **não conformidade e ação corretiva**. Este item detalha como a organização deve reagir a não conformidades e implementar ações corretivas eficazes.

Portanto, a resposta correta é: c) não conformidade e ação corretiva.

Letra c.

014. (VUNESP/AUDITOR-FISCAL TRIBUTÁRIO MUNICIPAL (PREF SP)/TECNOLOGIA DA INFORMAÇÃO/2023) A norma ABNT NBR ISO/IEC 27001:2022 (Segurança da informação, segurança cibernética e proteção à privacidade – Sistemas de gestão da segurança da informação – Requisitos) estabelece condições para os objetivos da segurança da informação, sendo correto afirmar que tal norma define que:

- esses objetivos devem ser mensuráveis (se praticável) e monitorados.
- esses objetivos são estabelecidos em um pré-projeto e não mais atualizados.
- dentre tais objetivos, encontra-se a necessidade de contar com equipes experientes.
- não há necessidade de documentar tais objetivos, visto que não mais poderão ocorrer após a validação do sistema.
- dentre tais objetivos, fica estabelecido um tempo máximo para a eliminação dos riscos de segurança.



- Certa. A norma ABNT NBR ISO/IEC 27001:2022 estabelece requisitos claros para os objetivos da segurança da informação no contexto de um SGSI. Entre os aspectos abordados, a norma especifica que os objetivos de segurança da informação devem ser mensuráveis (quando praticável) e monitorados. Isso garante que os objetivos sejam claros, possam ser avaliados ao longo do tempo e que o progresso em direção a eles possa ser medido. Portanto, a resposta correta é: a) esses objetivos devem ser mensuráveis (se praticável) e monitorados.
- Errada. Esta afirmação é incorreta porque a norma enfatiza a necessidade de rever e atualizar continuamente os objetivos de segurança da informação. Eles devem ser relevantes e adaptáveis às mudanças no ambiente de negócios, nas tecnologias e nas ameaças.

c) Errada. Embora contar com equipes experientes seja importante para a segurança da informação, a norma ISO/IEC 27001 não define objetivos específicos focados exclusivamente em ter equipes experientes. Os objetivos são mais amplos e se concentram na proteção da informação e na eficácia do SGSI.

d) Errada. Esta afirmação é incorreta porque a norma requer que os objetivos de segurança da informação sejam documentados. A documentação é essencial para garantir clareza, comunicação eficaz e permite a revisão e avaliação contínua da eficácia dos objetivos.

e) Errada. A norma não estabelece um tempo máximo para a eliminação dos riscos de segurança. Em vez disso, aborda o tratamento de riscos de segurança de forma contínua e baseada no contexto da organização, priorizando-os conforme a análise de riscos e os objetivos de segurança da informação.

Letra a.

015. (CESPE/TJ-AM/ANALISTA JUDICIÁRIO – ANALISTA DE SISTEMAS/2019/ADAPTADA) Julgue o próximo item, relativo à gestão de segurança da informação.

De acordo com a norma NBR ISO/IEC 27001 [de 2022, Versão corrigida 2023], uma organização que vise estabelecer um sistema de gestão de segurança da informação (SGSI) deve entender o contexto interno e externo da organização em relação aos riscos e aplicar um processo de avaliação de riscos de segurança da informação e uma análise qualitativa e quantitativa.



Na Seção 4.1 da NBR ISO/IEC 27001 [de 2022, Versão corrigida 2023] Entendendo a organização e seu contexto, a norma destaca que *“a organização deve determinar as questões internas e externas que são relevantes para o seu propósito e que afetam sua capacidade de alcançar os resultados pretendidos do seu sistema de gestão da segurança da informação”*.

NOTA A determinação destas questões refere-se ao estabelecimento do contexto interno e externo da organização apresentado na ABNT ISO 31000:2018, 5.4.1.

Ainda, a Seção 6 da norma NBR ISO/IEC 27001 cita que a **organização deve** estabelecer e aplicar um **processo de avaliação de riscos de segurança da informação**.

Certo.

016. (CESPE/TCE-RN/ASSESSOR TÉCNICO DE INFORMÁTICA – CONTROLE EXTERNO/2015/ADAPTADA) Julgue os itens a seguir, acerca de gestão de segurança da informação à luz das normas ISO/IEC 27001 (de 2022) e 27002.

Se, para manutenção de máquinas de uma organização é necessário eliminar quaisquer dados sensíveis das máquinas antes de serem manipuladas por pessoal externo à organização, diz-se que esse controle refere-se ao domínio de controles físicos.



Nesse contexto, os itens dos equipamentos que contenham mídia de armazenamento devem ser verificados para assegurar que quaisquer **dados sensíveis e software licenciado** tenham sido **removidos ou sobrescritos** com segurança antes do descarte ou reutilização. Tal controle é o 7.14 (descarte seguro ou reutilização de equipamentos) e está ligado ao domínio **controles físicos**.

Certo.

017. (CESPE/TCE RN/ASSESSOR TÉCNICO DE INFORMÁTICA/CONTROLE EXTERNO/2015)
Julgue os itens a seguir, acerca de gestão de segurança da informação à luz das normas ISO/IEC 27001 e 27002. A política de segurança deve ser aprovada pelo gestor máximo da instituição, assinada pelo chefe da informática, e divulgada para o pessoal de tecnologia da informação e comunicação (TIC).



A política de segurança da informação e as políticas específicas por tema devem ser definidas, aprovadas pela direção, publicadas, comunicadas e reconhecidas pelo pessoal pertinente e pelas partes interessadas pertinentes, e analisadas criticamente em intervalos planejados e quando ocorrerem mudanças significativas. Vide controle 5.1 da ISO/IEC 27001:2022 (versão corrigida 2023).

Errado.

018. (CESPE/TCE-RN/ASSESSOR TÉCNICO DE INFORMÁTICA/CONTROLE EXTERNO/2015)
Julgue os itens a seguir, acerca de gestão de segurança da informação à luz das normas ISO/IEC 27001 e 27002.

Um dos objetivos das auditorias internas do SGSI é determinar se seus controles são executados conforme esperado.



Em 9.2.1 da ISO/IEC 27001:2022 (versão corrigida 2023) temos que a organização deve conduzir **auditorias internas** a intervalos planejados para prover informações sobre se o SGSI:

- a) está em conformidade com:
 - 1) os próprios requisitos da organização para o seu sistema de gestão de segurança da informação;
 - 2) os requisitos da Norma ABNT NBR ISO/IEC 27001:2022 (versão corrigida 2023);
- b) está efetivamente implementado e mantido.

Dessa forma, um dos objetivos das auditorias internas do SGSI é determinar se seus controles são executados conforme esperado. Quando uma não conformidade for diagnosticada, a organização deve:

- a) avaliar a necessidade de ações para eliminar as causas de não conformidade;
- b) realizar mudanças no SGSI, quando necessárias, dentre outras.

Certo.

019. (CESPE/MCT/TECNOLOGISTA PLENO/SEGURANÇA DE SISTEMAS DE INFORMAÇÃO/ADAPTADA/2008) Uma organização que deseje implantar um sistema de gestão de segurança da informação (SGSI) deve adotar como base a norma ABNT NBR ISO/IEC 27001:2022



Inevitavelmente, uma organização que deseje implantar um **Sistema de Gestão de Segurança da Informação (SGSI)** deve adotar a norma ABNT NBR ISO/IEC 27001:2022 como base. A rigor, a norma é uma especificação (documento que é utilizado para a realização de auditorias e consequente certificação) de um SGSI.

Certo.

020. (INÉDITA/2024) A seção 4.3 da norma ISO/IEC 27001:2022 (versão corrigida 2023) trata os itens que a organização deve considerar quando da determinação do escopo.



A Seção 4.3 da norma ISO/IEC 27001:2022 (versão corrigida 2023) destaca que **a organização deve determinar os limites e a aplicabilidade do sistema de gestão da segurança da informação para estabelecer seu escopo.**

Quando da **determinação do escopo**, a organização deve considerar:

- As **questões internas e externas** que são relevantes para o seu propósito e que afetam sua capacidade para alcançar os resultados pretendidos do seu sistema de gestão de segurança da informação.
- Os **requisitos das partes interessadas relevantes para a segurança da informação.**
- As **interfaces e dependências entre as atividades** desempenhadas pela organização e aquelas que são desempenhadas por outras organizações.

Segundo a referida norma ISO/IEC 27001:2022 o escopo deve estar disponível como **informação documentada.**

Certo.

021. (CESPE/INMETRO/PESQUISADOR/CIÊNCIA DA COMPUTAÇÃO/2010) Com relação aos controles recomendados nas normas 27001 e 27002, é correto destacar que todos os controles que constam da norma devem ser implementados.



A norma **NÃO** faz esta exigência! Apenas a **não implementação de um controle é que deve ser devidamente justificada.**

Errado.

022. (CESPE/INMETRO – PESQUISADOR – CIÊNCIA DA COMPUTAÇÃO/2010) Com relação aos controles recomendados nas normas ISO/IEC 27001 e ISO/IEC 27002, é correto destacar que a implementação dos controles permite garantir a segurança da informação.



A implementação dos controles garante que as boas práticas de segurança da informação estão sendo seguidas.

Errado.

023. (CESPE/INMETRO – PESQUISADOR – CIÊNCIA DA COMPUTAÇÃO/2010) Com relação aos controles recomendados nas normas 27001 e 27002, é correto destacar que a norma 27001 define os controles que devem ser implementados.



Refere-se à Norma ISO/IEC 27002, que define os controles que **PODEM** ser implementados. A ISO/IEC 27001, por trazer requisitos obrigatórios, utiliza-se do **verbo “deve”**, enquanto a **ISO 27002** usa o **verbo “convém”** para suas diretrizes. Por exemplo, a ISO 27001 diz que “A Alta Direção **deve** estabelecer uma política de segurança da informação (...)”. Já a Norma ISO/IEC 27002 traz que “**Convém** que as políticas para a segurança da informação sejam analisadas criticamente a intervalos planejados ou quando mudanças significativas ocorrerem (...)”.

Errado.

024. (CESPE/INMETRO – PESQUISADOR – CIÊNCIA DA COMPUTAÇÃO/2010) Com relação aos controles recomendados nas normas 27001 e 27002, é correto destacar que a norma 27002 define os requisitos de um sistema de gestão de segurança da informação.



Não é correto afirmar que a norma ISO/IEC 27002 define os requisitos de um sistema de gestão de segurança da informação. Vamos esclarecer as funções de cada uma das normas:

- **ISO/IEC 27001:** esta é a norma que define os requisitos para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI).
- **ISO/IEC 27002:** esta norma complementa a ISO/IEC 27001 ao fornecer diretrizes para a implementação dos controles de segurança da informação.

Portanto, a ISO/IEC 27002 é um guia para a implementação de controles, enquanto a ISO/IEC 27001 é a norma que define os requisitos para um SGSI.

O texto refere-se à norma ABNT NBR ISO/IEC 27001.

Errado.

025. (CESPE/TCU/ANALISTA DE CONTROLE EXTERNO/TI/2007) A ISO 17799 define diretrizes para certificação de que uma organização está em conformidade à própria norma. Essa certificação é conferida por meio de uma auditoria de terceira parte, nos moldes da ISO 19011.



A ABNT NBR ISO/IEC 17799:2005 (renumerada para **ABNT NBR ISO/IEC 27002**) estabelece diretrizes e princípios gerais para estabelecer, implementar, manter e melhorar a gestão de segurança da informação em uma organização. Os objetivos definidos nesta norma proveem diretrizes gerais sobre as metas geralmente aceitas para a gestão da segurança da informação.

Cabe ressaltar que **não** há certificação para pessoas, somente para as empresas. E essa certificação é baseada na ISO/IEC 27001 e não na ISO/IEC 27002!

A norma 27001 é usada para fins de certificação (faz referência aos controles apenas para fins de checagem para certificação). É a norma que deve ser adotada como base para uma organização que deseja implantar um Sistema de Gestão de Segurança da Informação (**SGSI**). A rigor, essa norma é uma especificação (documento que é utilizado para a realização de auditorias e consequente certificação) de um SGSI.

Errado.

026. (CESPE/BANCO DA AMAZÔNIA/TÉCNICO CIENTÍFICO – ESPECIALIDADE: TECNOLOGIA DA INFORMAÇÃO/SEGURANÇA DA INFORMAÇÃO/2010) São exemplos de ativos de uma organização a informação e os processos de apoio, sistemas e redes. Os requisitos de segurança, em uma organização, são identificados por meio de análise sistemática dos riscos de segurança.



A segurança é uma palavra que está presente em nosso cotidiano e refere-se a um estado de proteção, livre de perigos e incertezas. Em uma corporação, a segurança está ligada a

todos os “objetos” de valor, que necessitam de proteção. Tais objetos são considerados como **ativos** (RAMOS *et al.*, 2006).

Segundo Sêmola (2003), **ativo** é tudo aquilo que tem um valor significativo para a empresa. São os **elementos que compõem e processam a informação, incluindo ela mesma**.

Esses ativos são essenciais para a operação e sucesso da organização, e, portanto, precisam ser protegidos adequadamente. Em linhas gerais, os ativos podem ser divididos nas categorias especificadas a seguir (SÊMOLA, 2003, p. 45).



Figura. Categorias de Ativos, conforme Sêmola (2023).

Cada grupo tem sua importância no ambiente corporativo, pois sem eles o negócio da organização não funciona, ou seja, ela terá problemas no seu dia a dia.

Vamos à análise de cada um deles!

- **Aplicações:** engloba todos os programas de computador utilizados para a automatização de processos, isto é, acesso, leitura, trânsito, armazenamento e processamento das informações. Ex.: sistema de Folha de Pagamento, sistemas operacionais, etc.
- **Informação:** pode estar registrada em meio eletrônico ou físico. Deve-se considerar qualquer tipo de informação, independentemente do tipo de meio em que esteja armazenada, que seja importante para a empresa e seus negócios.
- **Usuários (ou pessoas):** refere-se aos indivíduos que utilizam a estrutura tecnológica e de comunicação da empresa e que lidam com a informação. Ex.: usuários do setor de RH, direção da empresa etc.
- **Equipamentos:** toda a infraestrutura tecnológica que oferece suporte à informação, durante seu uso, trânsito, processamento e armazenamento. Faz parte desse grupo qualquer equipamento no qual se armazene, processe ou transmita as informações da empresa, como microcomputadores, servidores, roteadores, switches.
- **Organização:** neste grupo, conforme Technet (2006), estão incluídos os aspectos que compõem a estrutura física e organizacional das empresas. Refere-se à organização lógica e física do pessoal dentro da empresa em questão. Ex.: a estrutura departamental e funcional, a distribuição de funções e os fluxos de informação da empresa os servidores. Em relação ao ambiente físico, entre outros, são considerados: salas e armários em que estão localizados os documentos, fitoteca, sala de servidores, etc.

Conforme visto, os elementos considerados na questão (**informações, equipamentos, usuários, aplicações e processos de apoio**) são exemplos de ativos. Quanto aos **requisitos**

de segurança, em uma organização, cabe destacar que são identificados por meio de análise sistemática dos riscos de segurança da informação.

Certo.

027. (FGV/MPE-AL/ANALISTA DO MINISTÉRIO PÚBLICO – DESENVOLVIMENTO DE SISTEMAS/2018) Assinale a opção que melhor descreve o princípio geral da norma ISO/IEC 27001.

- a) Definir os procedimentos e tarefas adequados à mitigação de riscos no âmbito de um sistema de gestão de segurança da informação.
- b) Definir os requisitos necessários para estabelecer, implementar, manter e melhorar de forma contínua um sistema de gestão de segurança da informação.
- c) Estabelecer os papéis, responsabilidades e atuação dos profissionais de segurança da informação numa organização.
- d) Orientar e alertar as organizações e seus respectivos profissionais em diversos aspectos relativos à gestão de segurança da informação.
- e) Prover uma coleção de artefatos tecnológicos que permitam a identificação, avaliação e eliminação de ataques aos ativos de segurança da informação.



A ISO/IEC 27001 é uma norma internacional **que especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente (EIMM) um Sistema de Gestão de Segurança da Informação (SGSI)** dentro do contexto da organização.

A opção que melhor descreve o princípio geral da norma ISO/IEC 27001 é:

- b) Definir os requisitos necessários para estabelecer, implementar, manter e melhorar de forma contínua um sistema de gestão de segurança da informação.**

Letra b.

028. (FCC/MPE-PE/ANALISTA MINISTERIAL/INFORMÁTICA/2018/ADAPTADA) Dentre os controles mencionados no Anexo A da norma NBR ISO/IEC 27001:2022 está: “Todos os funcionários da organização e, onde pertinente, as partes externas devem receber treinamento, educação e conscientização apropriados, e as atualizações regulares das políticas e procedimentos organizacionais relevantes para as suas funções.” Este controle é parte do domínio:

- a) Segurança nas operações.
- b) Política de segurança da informação.
- c) Controles de pessoas.
- d) Organização da segurança da informação.
- e) Segurança física e do ambiente.



O controle mencionado, que se refere ao treinamento, educação e conscientização de funcionários e partes externas sobre políticas e procedimentos organizacionais relevantes para suas funções, faz parte do domínio: c) **Controles de pessoas**.

Este domínio é focado em garantir que as pessoas que interagem com os sistemas da organização sejam devidamente treinadas e cientes das políticas de segurança da informação, ajudando a prevenir erros humanos e a garantir que todos compreendam suas responsabilidades e o impacto potencial de suas ações na segurança da informação.

O domínio **Controles de pessoas** especifica controles para antes da contratação, durante e após a contratação.

6	Controles de pessoas	
6.3	Conscientização, educação e treinamento em segurança da informação	Controle O pessoal da organização e partes interessadas relevantes devem receber treinamento, educação e conscientização em segurança da informação apropriados e atualizações regulares da política de segurança da informação da organização, políticas e procedimentos específicos por tema, pertinentes para as suas funções.

Fonte: ISO/IEC 27001:2022 (versão corrigida 2023)

Letra c.

029. (FCC/ARTESP/ESPECIALISTA EM REGULAÇÃO DE TRANSPORTE I/TECNOLOGIA DA INFORMAÇÃO/2017) Uma organização deve determinar e prover recursos necessários para o estabelecimento, implementação, manutenção e melhoria contínua da gestão da segurança da informação. Dentre esses recursos estão as pessoas que realizam o trabalho sob o controle da organização. Segundo a norma ABNT NBR ISO/IEC 27001:2022, todas estas pessoas devem estar cientes

- a) do plano de continuidade de negócios e de suas responsabilidades e papéis, já que todos participam quando é necessário colocar este plano em prática.
- b) do plano estratégico, que estabelece a direção a ser seguida pela organização para melhorar o sistema de gestão da segurança da informação.
- c) do plano operacional, que define as ações e metas traçadas para atingir os objetivos das decisões estratégicas relacionadas à segurança da informação.
- d) de suas responsabilidades no processo de gestão de riscos de segurança da informação, atuando como observadoras das ações dos demais funcionários na identificação de potenciais riscos de segurança da informação.
- e) das implicações da não conformidade com os requisitos do sistema de gestão da segurança da informação.



A **seção 7.3** (“**Conscientização**”) da norma ABNT NBR ISO/IEC 27001:2022 **destaca** que as **pessoas que realizam trabalho** sob o controle da organização **devem estar cientes de:**

- a) Política de Segurança da Informação,**
- b) suas contribuições para a eficácia do SGSI;** e
- c) implicações da não conformidade** com os requisitos do **SGSI**.

Portanto, a resposta correta é:

e) das implicações da não conformidade com os requisitos do sistema de gestão da segurança da informação.

a) Errada. Plano de continuidade de negócios: embora seja importante que certos funcionários conheçam suas responsabilidades no plano de continuidade de negócios, a ISO/IEC 27001 foca nas responsabilidades gerais relacionadas à segurança da informação.

b) Errada. Plano estratégico: o conhecimento do plano estratégico pode ser relevante para alguns níveis de gestão, mas a norma enfatiza a consciência sobre segurança da informação e suas implicações, mais do que planos estratégicos amplos.

c) Errada. Plano operacional: novamente, enquanto relevante para implementar ações específicas, o foco da norma está em assegurar que todos compreendam as responsabilidades de segurança mais amplas.

d) Errada. Gestão de riscos como observadoras: embora a gestão de riscos seja importante, a ISO/IEC 27001 requer mais do que apenas observação; ela busca um entendimento ativo das responsabilidades e implicações.

A opção **e** reflete a necessidade de uma compreensão abrangente e prática da importância da conformidade com o SGSI.

Letra e.

030. (FGV/DPE-RJ/TÉCNICO SUPERIOR ESPECIALIZADO/SEGURANÇA DA INFORMAÇÃO/2014)

Uma instituição pretende implantar um sistema de gestão da segurança da informação.

Para isso, ela deve seguir as orientações da norma:

- a) ISO 27001.
- b) ISO 27002.
- c) ISO 27005.
- d) ISO 27006.
- e) ISO 27010.



a) Certa. Para implantar um Sistema de Gestão da Segurança da Informação (SGSI), a instituição deve seguir as orientações da norma:

a) ISO/IEC 27001.

A Norma NBR ISO/IEC 27001:2022 especifica os **requisitos para estabelecer, implementar, manter e melhorar continuamente (EIMM) um Sistema de Gestão de Segurança da Informação (SGSI) dentro do contexto da organização.**

Vamos entender também o papel das outras normas mencionadas:

b) Errada. ISO 27002 -> Código de Melhores Práticas para a Gestão de Segurança da Informação. Ela complementa a ISO/IEC 27001 fornecendo informações detalhadas sobre a implementação dos controles listados na ISO/IEC 27001.

c) Errada. ISO 27005 -> Gestão de Riscos de Segurança da Informação. Focada na gestão de riscos relacionados à segurança da informação, esta norma fornece diretrizes sobre como gerenciar riscos de forma eficaz, mas não define requisitos para um SGSI completo.

d) Errada. ISO 27006 -> Requisitos para auditorias externas em um Sistema de Gerenciamento de Segurança da Informação. Especifica como o processo de auditoria de um sistema de gerenciamento de segurança da informação deve ocorrer.

Esta norma é direcionada a organismos de certificação e especifica requisitos para auditar e certificar um SGSI em conformidade com a ISO/IEC 27001.

e) Errada. ISO 27010 -> Gestão de Segurança da Informação para Comunicações Inter Empresariais. Tem foco nas melhores formas de comunicar, acompanhar, monitorar grandes incidentes e fazer com que isso seja feito de forma transparente entre empresas particulares e governamentais.

Letra a.

031. (ESAF/MPOG/ANALISTA DE PLANEJAMENTO E ORÇAMENTO-APO-TI/2008) A segurança da informação tem como objetivo a preservação da

- a) confidencialidade, interatividade e acessibilidade informações.
- b) complexidade, integridade e disponibilidade das informações.
- c) confidencialidade, integridade e acessibilidade das informações.
- d) universalidade, interatividade e disponibilidade das informações.
- e) confidencialidade, integridade e disponibilidade das informações.



A segurança da informação tem como objetivo a preservação de três princípios fundamentais conhecidos como a tríade **CID**:

e) confidencialidade, integridade e disponibilidade das informações.

- **Confidencialidade:** assegura que a informação seja acessada apenas por pessoas autorizadas, protegendo-a contra acessos não autorizados.

- **Integridade:** garante que a informação seja mantida de forma precisa e completa, protegendo-a contra alterações indevidas.
- **Disponibilidade:** assegura que a informação esteja acessível e utilizável sob demanda pelas pessoas autorizadas.

Portanto, a resposta correta é a opção **e**.

Quando falamos sobre segurança da informação, estamos nos referindo às medidas de proteção destinadas a garantir a confidencialidade, integridade, disponibilidade e outros aspectos da segurança das informações, de acordo com as necessidades do cliente.

Letra e.

032. (FCC/INFRAERO/ANALISTA/SEGURANÇA DA INFORMAÇÃO/2011/ADAPTADA) Sobre a norma ABNT NBR ISO/IEC 27001:2022, é INCORRETO afirmar:

- Promove a adoção de uma abordagem de processo para estabelecer e implementar, operar, monitorar, analisar criticamente, manter e melhorar o SGSI de uma organização.
- Foi desenvolvida para organizações privadas e seus requisitos genéricos não são aplicáveis às organizações públicas ou privadas de pequeno porte.
- Especifica os requisitos para estabelecer, implementar, operar, monitorar, analisar criticamente, manter e melhorar um SGSI documentado dentro do contexto dos riscos de negócio globais da organização.
- Especifica requisitos para a implementação de controles de segurança personalizados para as necessidades individuais de organizações ou suas partes.



Vamos analisar cada uma das assertivas sobre a norma ABNT NBR ISO/IEC 27001:2022 para identificar qual delas é incorreta:

- Certa. A norma realmente incentiva a adoção de uma abordagem de processo. Isso inclui todas as fases de um ciclo PDCA (Plan-Do-Check-Act) para garantir que o SGSI seja continuamente atualizado e melhorado.
- Errada. Dentre as assertivas, a B é falsa. A norma ABNT NBR ISO/IEC 27001:2022 cobre **TODOS** os tipos de organizações (por exemplo, empreendimentos comerciais, agências governamentais, organizações sem fins lucrativos). Seus requisitos genéricos foram elaborados para serem flexíveis e adaptáveis a diversas organizações, incluindo as de pequeno porte.
- Certa. Esta afirmação é precisa. A norma especifica um conjunto de requisitos para gerenciar a segurança da informação dentro do contexto dos riscos de negócio que a organização enfrenta, garantindo que o SGSI seja um reflexo dos desafios específicos de cada organização.

d) Certa. A norma permite que organizações selecionem e implementem controles de segurança que sejam apropriados para suas necessidades específicas, com base em uma avaliação de riscos. Isso significa que as organizações podem personalizar sua abordagem de segurança da informação para alinhar com seus riscos e objetivos particulares.

Letra b.

033. (FUMARC/PRODEMGE/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO/2011) A norma ISO/IEC 27001 foi elaborada para prover um modelo de sistema de gestão de segurança da informação (SGSI) e também para avaliar a conformidade deste pelas partes interessadas internas e externas.



A norma ISO/IEC 27001 é fundamental para estabelecer um sistema de gestão da segurança da informação (SGSI) eficaz e foi preparada para prover um modelo para estabelecer, implementar, operar, monitorar, analisar criticamente.

A adoção de um SGSI deve ser uma decisão estratégica para uma organização. A especificação e a implementação do SGSI de uma organização são influenciadas pelas suas necessidades e objetivos, requisitos de segurança, processos empregados e tamanho e estrutura da organização. É esperado que este e os sistemas de apoio mudem com o passar do tempo. É esperado que a implementação de um SGSI seja escalada conforme as necessidades da organização, por exemplo, uma situação simples requer uma solução de um SGSI simples.

Esta norma pode ser usada para avaliar a conformidade pelas partes interessadas internas e externas.

Em resumo, a ISO/IEC 27001 serve tanto como um guia para estabelecer um SGSI robusto quanto como um ponto de referência para a avaliação de conformidade, o que é crucial para ganhar a confiança das partes interessadas e proteger os ativos de informação da organização.

Certo.

034. (FCC/TRE-RR/ANALISTA JUDICIÁRIO/ANÁLISE DE SISTEMAS/2015) Considere que um determinado Tribunal Regional Eleitoral esteja definindo uma forma de gerenciar riscos da infraestrutura de TI, incluindo a determinação de políticas, procedimentos, diretrizes, práticas e estruturas organizacionais para estabelecer proteções e contramedidas. De acordo com a Norma ISO/IEC 27002, essa definição para segurança da informação é denominada

- a) Ativo
- b) Evento
- c) Controle

- d) Recurso
- e) Política



Vamos à descrição de cada um dos termos aqui listados:

a) Errada. Na ISO/IEC 27002, **ativo** é algo que tem valor para a organização e que requer adequada proteção. Exemplos: ativos primários (processos e atividades de negócio, informação) e ativos de suporte e infraestrutura (sobre os quais os elementos primários do escopo se apoiam), que são: hardware, software, rede, recursos humanos, instalações físicas, estrutura da organização [ABNT NBR ISO/IEC 17799:2005]. A gestão de riscos não se refere a um ativo em si, mas ao processo de proteção desses ativos.

b) Errada. **Evento, no contexto de segurança da informação**, é uma ocorrência identificada de um sistema, serviço ou rede, que indica uma possível violação da política de segurança da informação ou falha de controles, ou uma situação previamente desconhecida, que possa ser relevante para a segurança da informação [ISO/IEC TR 18044:2004]. Não se trata do processo de gerenciar riscos ou estabelecer proteções e contramedidas.

c) Certa. **Controle** é uma forma de gerenciar o risco, incluindo políticas, procedimentos, diretrizes, práticas ou estruturas organizacionais, que podem ser de natureza administrativa, técnica, de gestão ou legal. Controle também é usado como sinônimo para proteção ou contramedida [ABNT NBR ISO/IEC 17799:2005]. Dessa forma, na norma ISO/IEC 27002, os controles são o foco para estabelecer proteções e contramedidas, o que torna esta a resposta correta à pergunta.

d) Errada. **Recursos de processamento de informação** designa qualquer sistema de processamento da informação, serviço ou infraestrutura, ou as instalações físicas que os abriguem [ABNT NBR ISO/IEC 17799:2005]. Embora recursos possam ser utilizados para implementar controles (por exemplo, recursos humanos ou financeiros), o termo não é especificamente usado para descrever o processo de definição de políticas e estruturas de segurança da informação.

e) Errada. O termo **política** designa as intenções e diretrizes globais formalmente expressas pela direção [ABNT NBR ISO/IEC 17799:2005], que guiam a gestão da segurança da informação. Enquanto as políticas são um componente importante do sistema de gestão de segurança da informação, elas não abrangem todo o processo de definição de controles como mencionado na questão.

Assim, na definição e implementação de medidas para gerenciar riscos de segurança da informação, a opção **c) Controle** é a que mais se alinha ao descrito na ISO/IEC 27002.

Letra c.

REFERÊNCIAS

ABNT NBR ISO/IEC 270001. *Segurança da informação, segurança cibernética e proteção à privacidade* – Sistemas de gestão da segurança da informação. Rio de Janeiro, 2022.

ABNT NBR ISO/IEC 27002. *Segurança da informação, segurança cibernética e proteção de privacidade* – Controles de segurança da informação. Rio de Janeiro, 2022.

ABNT NBR ISO/IEC 27003. *Tecnologia da informação* – Técnicas de segurança – Sistemas de gestão da segurança da informação – Orientações.

ABNT NBR ISO/IEC 27005. *Tecnologia da Informação* – Técnicas de segurança – Gestão de riscos de segurança da informação. Rio de Janeiro, 2008.

LEAL, R. *O que é a ISO 27001?* 2015. Disponível em: <<https://advisera.com/27001academy/pt-br/o-que-e-a-iso-27001/>>. Acesso em: 10 ago. de 2020.

QUINTÃO, P. L. *Notas de Aula da disciplina “Tecnologia da Informação”*. 2023.

_____. *Informática-FCC-Questões Comentadas e Organizadas por Assunto*, 3ª. Edição. Ed. Gen/Método, 2014.

_____. *1001 Questões Comentadas de Informática* – Cespe, 2ª. Edição. Ed. Gen/Método, 2017.

_____. *Notas de aula sobre normas da ABNT de segurança*. 2023.

ANEXO

ANEXO A (NORMATIVO)

Vejamos os **93 controles** a seguir:

Tabela A.1 – Controles de Segurança da Informação

5	Controles organizacionais	
5.1	Políticas de segurança da informação	Controle A política de segurança da informação e as políticas específicas por tema devem ser definidas, aprovasdas pela direção, publicadas, comunicadas e reconhecidas pelo pessoal pertinente e pelas partes interessadas pertinentes , e analisadas criticamente em intervalos planejados e quando ocorrerem mudanças significativas.
5.2	Papéis e responsabilidades pela segurança da informação	Controle Papéis e responsabilidades pela segurança da informação devem ser definidos e alocados de acordo com as necessidades da organização.
5.3	Segregação de funções	Controle Funções conflitantes e áreas de responsabilidade devem ser segregadas.
5.4	Responsabilidades da direção	Controle A direção deve requerer que todo o pessoal aplique a segurança da informação de acordo com a política da segurança da informação estabelecida, com as políticas específicas por tema e com os procedimentos da organização.
5.5	Contato com autoridades	Controle A organização deve estabelecer e manter contato com as autoridades relevantes.
5.6	Contato com grupos de interesse especial	Controle A organização deve estabelecer e manter contato com grupos de interesse especial ou com outros fóruns de especialistas em segurança e associações profissionais.
5.7	Inteligência de ameaças	Controle As informações relacionadas a ameaças à segurança da informação devem ser coletadas e analisadas para produzir inteligência de ameaças.
5.8	Segurança da informação no gerenciamento de projetos	Controle A segurança da informação deve ser integrada ao gerenciamento de projetos.
5.9	Inventário de informações e outros ativos associados	Controle Um inventário de informações e outros ativos associados, incluindo proprietários, deve ser desenvolvido e mantido.

5.10	Uso aceitável de informações e outros ativos associados	Controle Regras para o uso aceitável e procedimentos para o manuseio de informações e outros ativos associados devem ser identificados, documentados e implementados.
5.11	Devolução de ativos	Controle O pessoal e outras partes interessadas, conforme apropriado, devem devolver todos os ativos da organização em sua posse após a mudança ou o encerramento da contratação ou acordo.
5.12	Classificação das informações	Controle As informações devem ser classificadas de acordo com as necessidades de segurança da informação da organização, com base na confidencialidade, integridade, disponibilidade e requisitos das partes interessadas relevantes.
5.13	Rotulagem de informações	Controle Um conjunto adequado de procedimentos para rotulagem de informações deve ser desenvolvido e implementado de acordo com o esquema de classificação de informações adotado pela organização.
5.14	Transferência de informações	Controle Regras, procedimentos ou acordos de transferência de informações devem ser implementados para todos os tipos de recursos de transferência dentro da organização e entre a organização e outras partes.
5.15	Controle de acesso	Controle Regras para controlar o acesso físico e lógico às informações e a outros ativos associados devem ser estabelecidas e implementadas com base nos requisitos de segurança da informação e de negócios.
5.16	Gestão de identidade	Controle O ciclo de vida completo das identidades deve ser gerenciado.
5.17	Informações de autenticação	Controle A alocação e a gestão de informações de autenticação devem ser controladas por uma gestão de processo, incluindo aconselhar o pessoal sobre o manuseio adequado de informações de autenticação.
5.18	Direitos de acesso	Controle Os direitos de acesso às informações e a outros ativos associados devem ser provisionados, analisados criticamente, modificados e removidos de acordo com a política de tema específico e com as regras da organização para o controle de acesso.
5.19	Segurança da informação nas relações com fornecedores	Controle Processos e procedimentos devem ser definidos e implementados para gerenciar a segurança da informação e os riscos associados com o uso dos produtos ou serviços dos fornecedores.
5.20	Abordagem da segurança da informação nos contratos de fornecedores	Controle Requisitos relevantes de segurança da informação devem ser estabelecidos e acordados com cada fornecedor, com base no tipo de relacionamento com o fornecedor.

5.21	Gestão da segurança da informação na cadeia de fornecimento de TIC	Controle Processos e procedimentos devem ser definidos e implementados para gerenciar os riscos da segurança da informação associados à cadeia de fornecimento de produtos e serviços de TIC.
5.22	Monitoramento, análise crítica e gestão de mudanças dos serviços de fornecedores	Controle A organização deve monitorar, analisar criticamente, avaliar e gerenciar regularmente a mudança nas práticas da segurança da informação dos fornecedores e na prestação de serviços.
5.23	Segurança da informação para uso de serviços em nuvem	Controle Os processos de aquisição, uso, gestão e saída de serviços em nuvem devem ser estabelecidos de acordo com os requisitos da segurança da informação da organização.
5.24	Planejamento e preparação da gestão de incidentes da segurança da informação	Controle A organização deve planejar e se preparar para gerenciar incidentes da segurança da informação, definindo, estabelecendo e comunicando processos, papéis e responsabilidades de gestão de incidentes da segurança da informação.
5.25	Avaliação e decisão sobre eventos da segurança da informação	Controle A organização deve avaliar os eventos da segurança da informação e decidir se categoriza como incidentes da segurança da informação.
5.26	Resposta a incidentes da segurança da informação	Controle Os incidentes da segurança da informação devem ser respondidos de acordo com os procedimentos documentados.
5.27	Aprendizado com incidentes de segurança da informação	Controle O conhecimento adquirido com incidentes de segurança da informação deve ser usado para fortalecer e melhorar os controles da segurança da informação.
5.28	Coleta de evidências	Controle A organização deve estabelecer e implementar procedimentos para identificação, coleta, aquisição e preservação de evidências relacionadas a eventos da segurança da informação.
5.29	Segurança da informação durante a interrupção	Controle A organização deve planejar como manter a segurança da informação em um nível apropriado durante a interrupção.
5.30	Prontidão de TIC para continuidade de negócios	Controle A prontidão de TIC deve ser planejada, implementada, mantida e testada com base nos objetivos de continuidade de negócios e nos requisitos de continuidade da TIC.
5.31	Requisitos legais, estatutários, regulamentares e contratuais	Controle Os requisitos legais, estatutários, regulamentares e contratuais pertinentes à segurança da informação e à abordagem da organização para atender a esses requisitos devem ser identificados, documentados e atualizados.
5.32	Direitos de propriedade intelectual	Controle A organização deve implementar procedimentos adequados para proteger os direitos de propriedade intelectual.

5.33	Proteção de registros	Controle Os registros devem ser protegidos contra perdas, destruição, falsificação, acesso não autorizado e liberação não autorizada.
5.34	Privacidade e proteção de DP	Controle A organização deve identificar e atender aos requisitos relativos à preservação da privacidade e à proteção de DP, de acordo com as leis e os regulamentos aplicáveis e requisitos contratuais.
5.35	Análise crítica independente da segurança da informação	Controle A abordagem da organização para gerenciar a segurança da informação e sua implementação, incluindo pessoas, processos e tecnologias, deve ser analisada criticamente, de forma independente, a intervalos planejados ou quando ocorrerem mudanças significativas.
5.36	Compliance com políticas, regras e normas para segurança da informação	Controle O <i>compliance</i> da política de segurança da informação da organização, políticas, regras e normas de temas específicos deve ser analisado criticamente a intervalos regulares.
5.37	Documentação dos procedimentos de operação	Controle Os procedimentos de operação dos recursos de tratamento da informação devem ser documentados e disponibilizados para o pessoal que necessite deles.

6	Controles de pessoas	
6.1	Seleção	Controle Verificações de antecedentes de todos os candidatos a serem contratados devem ser realizadas antes de ingressarem na organização e de modo contínuo, de acordo com as leis, os regulamentos e a ética aplicáveis, e devem ser proporcionais aos requisitos do negócio, à classificação das informações a serem acessadas e aos riscos percebidos.
6.2	Termos e condições de contratação	Controle Os contratos trabalhistas devem declarar as responsabilidades do pessoal e da organização para a segurança da informação.
6.3	Conscientização, educação e treinamento em segurança da informação	Controle O pessoal da organização e partes interessadas relevantes devem receber treinamento, educação e conscientização em segurança da informação apropriados e atualizações regulares da política de segurança da informação da organização, políticas e procedimentos específicos por tema, pertinentes para as suas funções.
6.4	Processo disciplinar	Controle Um processo disciplinar deve ser formalizado e comunicado, para tomar ações contra pessoal e outras partes interessadas relevantes que tenham cometido uma violação da política da segurança da informação.

6.5	Responsabilidades após encerramento ou mudança da contratação	Controle As responsabilidades e funções de segurança da informação que permaneçam válidas após o encerramento ou a mudança da contratação devem ser definidas, aplicadas e comunicadas ao pessoal e a outras partes interessadas pertinentes.
6.6	Acordos de confidencialidade ou não divulgação	Controle Acordos de confidencialidade ou não divulgação que reflitam as necessidades da organização para a proteção das informações devem ser identificados, documentados, analisados criticamente em intervalos regulares e assinados pelo pessoal e por outras partes interessadas pertinentes.
6.7	Trabalho remoto	Controle Medidas de segurança devem ser implementadas quando as pessoas estiverem trabalhando remotamente para proteger as informações acessadas, tratadas ou armazenadas fora das instalações da organização.
6.8	Relato de eventos de segurança da informação	Controle A organização deve fornecer um mecanismo para que as pessoas relatem eventos de segurança da informação observados ou suspeitos por meio de canais apropriados em tempo hábil.

7	Controles físicos	
7.1	Perímetros de segurança física	Controle Perímetros de segurança devem ser definidos e usados para proteger áreas que contenham informações e outros ativos associados.
7.2	Entrada física	Controle As áreas seguras devem ser protegidas por controles de entrada e pontos de acesso apropriados.
7.3	Segurança de escritórios, salas e instalações	Controle Segurança física para escritórios, salas e instalações deve ser projetada e implementada
7.4	Monitoramento de segurança física	Controle As instalações devem ser monitoradas continuamente para acesso físico não autorizado
7.5	Proteção contra ameaças físicas e ambientais	Controle Proteção contra ameaças físicas e ambientais, como desastres naturais e outras ameaças físicas intencionais ou não intencionais à infraestrutura, deve ser projetada e implementada.
7.6	Trabalho em áreas seguras	Controle Medidas de segurança para trabalhar em áreas seguras devem ser projetadas e implementadas.
7.7	Mesa limpa e tela limpa	Controle Regras de mesa limpa para documentos impressos e mídia de armazenamento removível e regras de tela limpa para os recursos de tratamento das informações devem ser definidas e adequadamente aplicadas.

7.8	Localização e proteção de equipamentos	Controle Os equipamentos devem ser posicionados com segurança e proteção.
7.9	Segurança de ativos fora das instalações da organização	Controle Os ativos fora das instalações da organização devem ser protegidos.
7.10	Mídia de armazenamento	Controle As mídias de armazenamento devem ser gerenciadas por seu ciclo de vida de aquisição, uso, transporte e descarte, de acordo com o esquema de classificação e com os requisitos de manuseio da organização.
7.11	Serviços de infraestrutura	Controle As instalações de tratamento de informações devem ser protegidas contra falhas de energia e outras interrupções causadas por falhas nos serviços de infraestrutura.
7.12	Segurança do cabeamento	Controle Os cabos que transportam energia ou dados, ou que sustentam serviços de informação, devem ser protegidos contra interceptação, interferência ou danos.
7.13	Manutenção de equipamentos	Controle Os equipamentos devem ser mantidos corretamente para assegurar a disponibilidade, integridade e confidencialidade da informação.
7.14	Descarte seguro ou reutilização de equipamentos	Controle Os itens dos equipamentos que contenham mídia de armazenamento devem ser verificados para assegurar que quaisquer dados confidenciais e <i>software</i> licenciado tenham sido removidos ou substituídos com segurança antes do descarte ou reutilização.
8	Controles tecnológicos	
8.1	Dispositivos <i>endpoint</i> do usuário	Controle As informações armazenadas, tratadas ou acessíveis por meio de dispositivos <i>endpoint</i> do usuário devem ser protegidas.
8.2	Direitos de acessos privilegiados	Controle A atribuição e o uso de direitos de acessos privilegiados devem ser restritos e gerenciados
8.3	Restrição de acesso à informação	Controle O acesso às informações e a outros ativos associados deve ser restrito de acordo com a política específica por tema sobre controle de acesso.
8.4	Acesso ao código-fonte	Controle Os acessos de leitura e escrita ao código-fonte, ferramentas de desenvolvimento e bibliotecas de <i>software</i> devem ser adequadamente gerenciados.
8.5	Autenticação segura	Controle Tecnologias e procedimentos de autenticação seguros devem ser implementados, com base em restrições de acesso à informação e à política específica por tema de controle de acesso.

8.6	Gestão de capacidade	Controle O uso dos recursos deve ser monitorado e ajustado de acordo com os requisitos atuais e esperados de capacidade.
8.7	Proteção contra <i>malware</i>	Controle Proteção contra <i>malware</i> deve ser implementada e apoiada pela conscientização adequada do usuário.
8.8.	Gestão de vulnerabilidades técnicas	Controle Informações sobre vulnerabilidades técnicas dos sistemas de informação em uso devem ser obtidas; a exposição da organização a tais vulnerabilidades deve ser avaliada e medidas apropriadas devem ser tomadas
8.9	Gestão de configuração	Controle As configurações, incluindo configurações de segurança, de <i>hardware</i> , <i>software</i> , serviços e redes, devem ser estabelecidas, documentadas, implementadas, monitoradas e analisadas criticamente.
8.10	Exclusão de informações	Controle As informações armazenadas em sistemas de informação, dispositivos ou em qualquer outra mídia de armazenamento devem ser excluídas quando não forem mais necessárias.
8.11	Mascaramento de dados	Controle O mascaramento de dados deve ser usado de acordo com a política específica por tema da organização sobre o controle de acesso e outros requisitos específicos por tema relacionados e requisitos de negócios, levando em consideração a legislação aplicável.
8.12	Prevenção de vazamento de dados	Controle As medidas de prevenção de vazamento de dados devem ser aplicadas a sistemas, redes e quaisquer outros dispositivos que tratem, armazenem ou transmitam informações sensíveis.
8.13	<i>Backup</i> das informações	Controle Cópias de <i>backup</i> de informações, <i>software</i> e sistemas devem ser mantidas e testadas regularmente de acordo com a política específica por tema acordada sobre <i>backup</i> .
8.14	Redundância dos recursos de tratamento de informações	Controle Os recursos de tratamento de informações devem ser implementados com redundância suficiente para atender aos requisitos de disponibilidade.
8.15	<i>Log</i>	Controle <i>Logs</i> que registrem atividades, exceções, falhas e outros eventos relevantes devem ser produzidos, armazenados, protegidos e analisados.
8.16	Atividades de monitoramento	Controle As redes, sistemas e aplicações devem ser monitorados por comportamentos anômalos e por ações apropriadas, tomadas para avaliar possíveis incidentes de segurança da informação.
8.17	Sincronização do relógio	Controle Os relógios dos sistemas de tratamento de informações utilizados pela organização devem ser sincronizados com fontes de tempo aprovadas.

8.18	Uso de programas utilitários privilegiados	Controle O uso de programas utilitários que possam ser capazes de substituir os controles de sistema e as aplicações deve ser restrito e rigorosamente controlado.
8.19	Instalação de <i>software</i> em sistemas operacionais	Controle Procedimentos e medidas devem ser implementados para gerenciar com segurança a instalação de <i>software</i> em sistemas operacionais.
8.20	Segurança de redes	Controle Redes e dispositivos de rede devem ser protegidos, gerenciados e controlados para proteger as informações em sistemas e aplicações.
8.21	Segurança dos serviços de rede	Controle Mecanismos de segurança, níveis de serviço e requisitos de serviços de rede devem ser identificados, implementados e monitorados.
8.22	Segregação de redes	Controle Grupos de serviços de informação, usuários e sistemas de informação devem ser segregados nas redes da organização.
8.23	Filtragem da web	Controle O acesso a <i>sites</i> externos deve ser gerenciado para reduzir a exposição a conteúdo malicioso.
8.24	Uso de criptografia	Controle Regras para o uso efetivo da criptografia, incluindo o gerenciamento de chaves criptográfica devem ser definidas e implementadas.
8.25	Ciclo de vida de desenvolvimento seguro	Controle Regras para o desenvolvimento seguro de <i>software</i> e sistemas devem ser estabelecidas e aplicadas.
8.26	Requisitos de segurança da aplicação	Controle Requisitos de segurança da informação devem ser identificados, especificados e aprovados ao desenvolver ou adquirir aplicações.
8.27	Princípios de arquitetura e engenharia de sistemas seguros	Controle Princípios de engenharia de sistemas seguros devem ser estabelecidos, documentados, mantidos e aplicados a qualquer atividade de desenvolvimento de sistemas.
8.28	Codificação segura	Controle Princípios de codificação segura devem ser aplicados ao desenvolvimento de <i>software</i> .
8.29	Testes de segurança em desenvolvimento e aceitação	Controle Processos de teste de segurança devem ser definidos e implementados no ciclo de vida do desenvolvimento.
8.30	Desenvolvimento terceirizado	Controle A organização deve dirigir, monitorar e analisar criticamente as atividades relacionadas à terceirização de desenvolvimento de sistemas.
8.31	Separação dos ambientes de desenvolvimento, teste e produção	Controle Ambientes de desenvolvimento, testes e produção devem ser separados e protegidos.

8.32	Gestão de mudanças	Controle Mudanças nos recursos de tratamento de informações e sistemas de informação devem estar sujeitas a procedimentos de gestão de mudanças.
8.33	Informações de teste	Controle Informações de teste devem ser adequadamente selecionadas, protegidas e gerenciadas.
8.34	Proteção de sistemas de informação durante os testes de auditoria	Controle Testes de auditoria e outras atividades de garantia envolvendo a avaliação de sistemas operacionais devem ser planejados e acordados entre o testador e a gestão apropriada.

Abra



caminhos



crie

futuros

gran.com.br

